



Rapport de Projet : Création d'une Vm vulnérable, Audit et Surveillance Active des OS

Programme : Bachelor Cybersécurité & Hacking Éthique

Module : PRJ-SYS11 (Système & OS : Lords of the Machines)

École 89

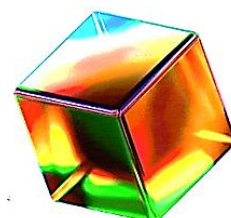
Samuel Emmanuel MEYISSO - Tristan Césaire

Date de rendu : 16/01/26

Nom du professeur référent : Monsieur Eddy MOZAR

Programme : Bachelor Cybersécurité & Hacking Éthique

Module : PRJ-SYS11 (Système & OS : Lords of the Machines)



Page de versioning

Version	Taches effectuées	Date	Personne
1.0	Création du document	17/12/25	Samuel
1.2	Rédaction et sommaire	18/12/25	Samuel
1.3	Conception de la Vm vulnérable Linux	20/12/25	Samuel
1.4	Audit des Utilisateurs et Permissions	21/12/25	Samuel
1.5	Audit systèmes Linux	27/12/25	Samuel
1.6	Conception de la Vm vulnérable Windows	27/12/25	Samuel
1.7	Implémentation dernière vulnérabilité Windows	28/12/25	Samuel
1.8	Surveillance des journaux et alertes	29/12/25	Samuel
1.9	Surveillance des journaux et alertes	30/12/25	Samuel
1.10	Surveillance des journaux et alertes	3/01/26	Samuel
1.11	Surveillance des journaux et alertes	4/01/26	Samuel
1.12	Surveillance des journaux et alertes	7/01/26	Samuel
1.13	Analyse des Résultats	8/01/26	Samuel
1.14	Recommandations de Sécurité	8/01/26	Samuel
1.15	Difficultés Rencontrées et Leçons Apprises	8/01/25	Samuel
1.16	Remédiation des vulnérabilités	13/01/25	Samuel
1.16	Conclusion	13/01/25	Samuel

Sommaire

01 Introduction

02 Contexte

03 Objectifs du projet

04 Conception de la Vm vulnérable Linux et Windows

05 Audit des Utilisateurs et Permissions

06 Audit systèmes Linux

07 Surveillance des Journaux et Alertes

08 Analyse des Résultats

09 Recommandations de Sécurité

10 Difficultés Rencontrées et Leçons Apprises

11 Conclusion

Introduction

La sécurité des systèmes d'exploitation constitue un enjeu majeur pour les organisations, la compréhension et la maîtrise des vulnérabilités sont essentielles pour tout professionnel de la cybersécurité. Ce projet, réalisé dans le cadre du module PRJ-SYS11 du Bachelor Cybersécurité & Hacking Éthique à l'École 89, propose une approche pratique et pédagogique de la gestion des vulnérabilités système sur deux environnements majeurs : Linux et Windows.

L'objectif principal est de concevoir un environnement Linux volontairement vulnérable, ainsi que d'auditer une machine Windows, puis de développer et d'appliquer des outils d'audit et de surveillance afin d'identifier, d'analyser et de remédier à ces faiblesses. Ce travail permet de mettre en œuvre les concepts abordés en cours, tout en développant une méthodologie rigoureuse d'analyse des risques et de renforcement de la sécurité sur des systèmes d'exploitation variés.

À travers la création de vulnérabilités, la rédaction de scripts d'audit (Bash pour Linux, PowerShell pour Windows), la mise en place de mécanismes de surveillance et l'analyse des résultats, ce projet vise à renforcer les compétences techniques et l'esprit critique nécessaires à la protection des systèmes d'information, quel que soit l'environnement.

Contexte

La sécurité des systèmes d'exploitation est un pilier fondamental de la cybersécurité. Les environnements Linux et Windows sont omniprésents dans les infrastructures informatiques modernes, et leur protection contre les vulnérabilités est essentielle pour garantir la confidentialité, l'intégrité et la disponibilité des données. Cependant, leur complexité croissante et la diversité des configurations rendent la détection et la correction des failles de sécurité de plus en plus difficiles.

En tant que futur professionnel de la cybersécurité, nous devons savoir identifier, analyser et remédier aux vulnérabilités présentes sur différents systèmes d'exploitation. Ce projet s'inscrit dans cette démarche, en proposant une mise en situation concrète où nous devons à la fois créer un

environnement vulnérable et développer des outils d'audit et de surveillance adaptés.

Objectifs du Projet

L'objectif principal de ce projet est de mettre en pratique les connaissances acquises en matière de sécurité des systèmes d'exploitation, à travers la réalisation des étapes suivantes :

Concevoir et configurer une machine virtuelle Linux présentant plusieurs vulnérabilités intentionnelles, en lien avec les thématiques du module PRJ-SYS11.

_Développer des scripts d'audit pour analyser la sécurité des environnements Linux et Windows, en identifiant les faiblesses et les mauvaises configurations.

_Mettre en place un mécanisme de surveillance active sur la VM Linux afin de détecter des événements suspects et générer des alertes.

_Analyser les résultats obtenus, confronter les découvertes aux vulnérabilités introduites, et proposer des recommandations concrètes de sécurisation (hardening) pour chaque environnement.

_Développer une démarche structurée de documentation, d'analyse et de restitution, afin de renforcer la rigueur et l'esprit critique indispensables en cybersécurité.

Ce projet vise ainsi à offrir une expérience complète, mêlant aspects techniques, méthodologiques et analytiques, sur deux systèmes d'exploitation majeurs du monde professionnel.

Conception de la VM Vulnérable Linux

Utilisation de Kali Linux pour première implémentation de vulnérabilités. Implémentation de 2 vulnérabilités telles que la permission de fichiers/répertoires incorrectes et la tâche cron mal sécurisée.

Première vulnérabilité : la permission de fichiers incorrectes

Création des fichiers via ligne de commandes Kali linux :

Passage en root avant implémentation de la vulnérabilité

Commande utilisée : **sudo su**

Puis vérification des droits du fichier avant et après implémentation de la vulnérabilité avec la commande : **ls -l**

On constate qu'avant l'implémentation de la vulnérabilité, le propriétaire en plus de pouvoir modifier le fichier pouvait le lire, le groupe propriétaire pouvait le lire aussi mais aucune autre personne ne pouvait le lire.

Après implémentation de la vulnérabilité, n'importe qui peut le lire et cela est dangereux même si on ne peut pas le modifier, ça cause une faille avantageuse pour les attaquants.

La conséquence de l'implémentation de cette première vulnérabilité, c'est que n'importe quel utilisateur peut lire le fichier vulnérable et tenter de casser les différents mots de passe en utilisant les hash du mot de passe qui se trouvent sur chaque ligne du fichier.

```
(root@kali)-[/home/kali/etc/shadow]
# pwd
/home/kali/etc/shadow

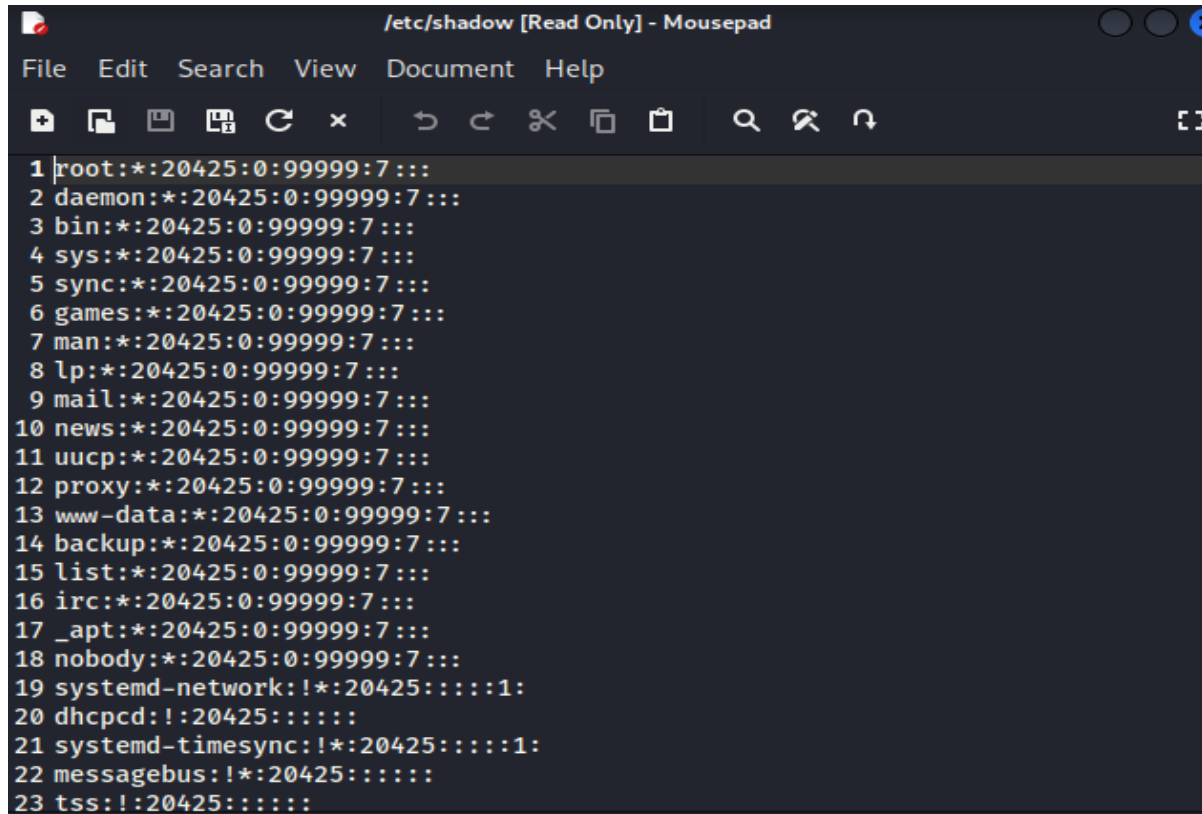
(root@kali)-[/home/kali/etc/shadow]
# ls -l /etc/shadow
-rw-r----- 1 root shadow 1448 Dec  2 21:36 /etc/shadow

(root@kali)-[/home/kali/etc/shadow]
# sudo chmod 644 /etc/shadow

(root@kali)-[/home/kali/etc/shadow]
# ls -l /etc/shadow
-rw-r--r-- 1 root shadow 1448 Dec  2 21:36 /etc/shadow

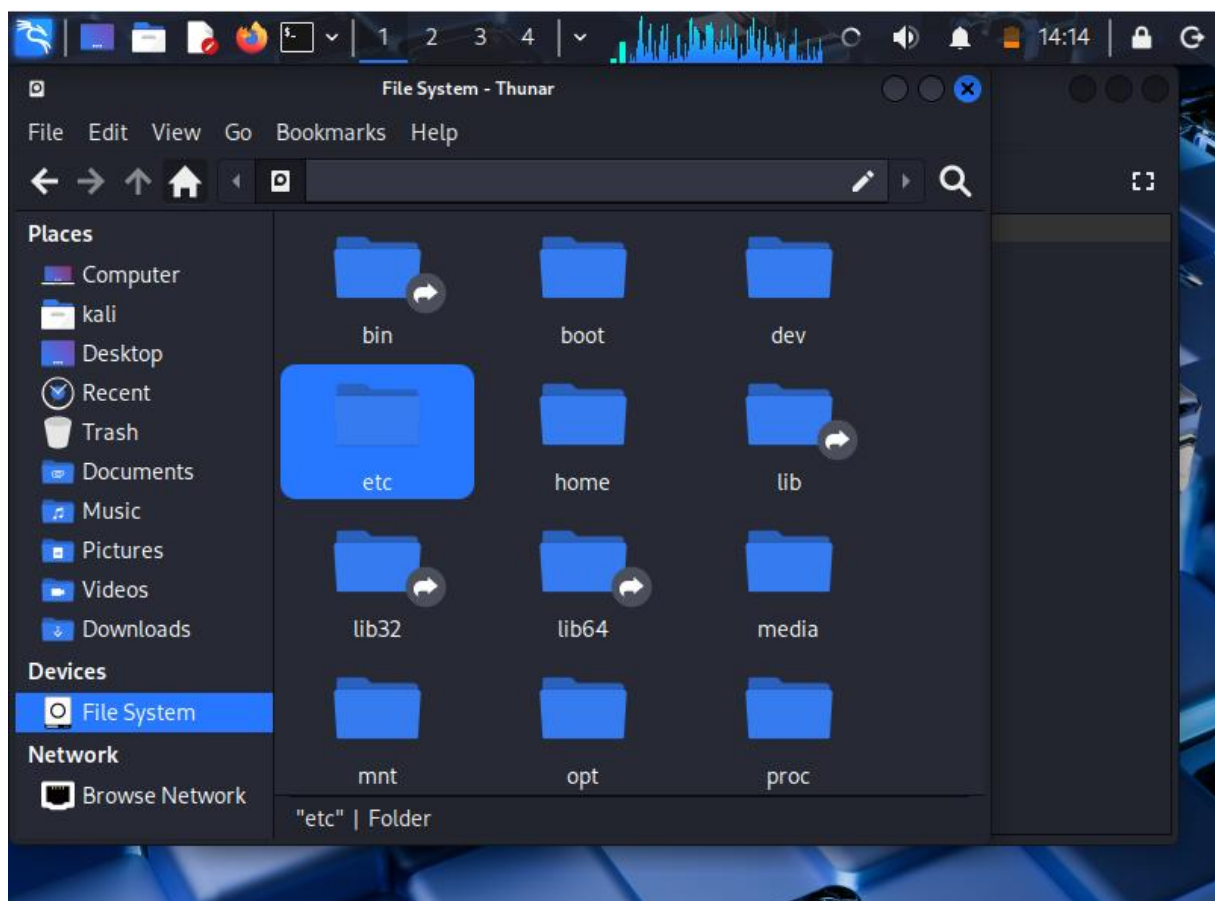
(root@kali)-[/home/kali/etc/shadow]
#
```

On voit bien que le fichier /etc/Shadow a été créé a bien été créé



The screenshot shows a text editor window titled "/etc/shadow [Read Only] - Mousepad". The window contains a list of system users and their shadow passwords, numbered 1 through 23. The entries are as follows:

```
1 root:!:20425:0:99999:7:::
2 daemon:!:20425:0:99999:7:::
3 bin:!:20425:0:99999:7:::
4 sys:!:20425:0:99999:7:::
5 sync:!:20425:0:99999:7:::
6 games:!:20425:0:99999:7:::
7 man:!:20425:0:99999:7:::
8 lp:!:20425:0:99999:7:::
9 mail:!:20425:0:99999:7:::
10 news:!:20425:0:99999:7:::
11 uucp:!:20425:0:99999:7:::
12 proxy:!:20425:0:99999:7:::
13 www-data:!:20425:0:99999:7:::
14 backup:!:20425:0:99999:7:::
15 list:!:20425:0:99999:7:::
16 irc:!:20425:0:99999:7:::
17 _apt:!:20425:0:99999:7:::
18 nobody:!:20425:0:99999:7:::
19 systemd-network:!:20425:0:99999:7:::1:
20 dhcpcd:!:20425:0:99999:7:::
21 systemd-timesync:!:20425:0:99999:7:::1:
22 messagebus:!:20425:0:99999:7:::
23 tss:!:20425:0:99999:7:::
```



Chaque ligne de `/etc/shadow` correspond à un utilisateur et contient, entre autres, le hash du mot de passe.

Un attaquant qui accède à ce fichier pourrait récupérer ces hash et tenter de les “casser” en d’autres termes, retrouver les mots de passes d’origine s’ils sont faibles en faisant du brute force.

Script d’audit vulnérabilité fichier/répertoire :

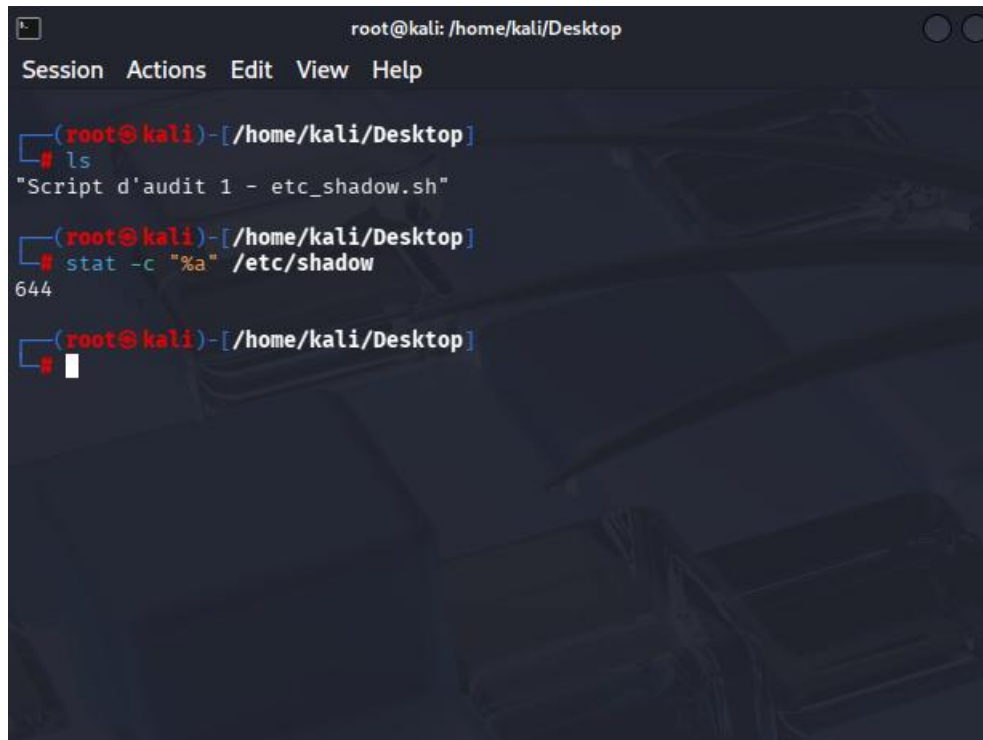
Le but de cet audit est de vérifier si le fichier est vulnérable à cause de permissions trop larges telles que 644 ou plus. Le fichier contient des hashes de mot de passe, nous devons donc nous assurer qu’il ne soit pas accessible à n’importe qui.

Utilisation de la commande **`stat -c "%a" /etc/shadow`** pour afficher les permissions du fichier. Si elle nous retourne 644, c’est que le fichier est vulnérable sinon il ne l’est pas.

Accéder à l’emplacement du fichier depuis le bureau

Ensuite exécution de la commande **`stat -c "%a" /etc/shadow`**.

Retour : 644. Le fichier est donc vulnérable

A terminal window titled 'root@kali: /home/kali/Desktop' with a menu bar (Session, Actions, Edit, View, Help). The user runs 'ls' and sees 'Script d\'audit 1 - etc_shadow.sh'. Then they run 'stat -c "%a" /etc/shadow' and see '644'.

```
root@kali: /home/kali/Desktop
Session Actions Edit View Help

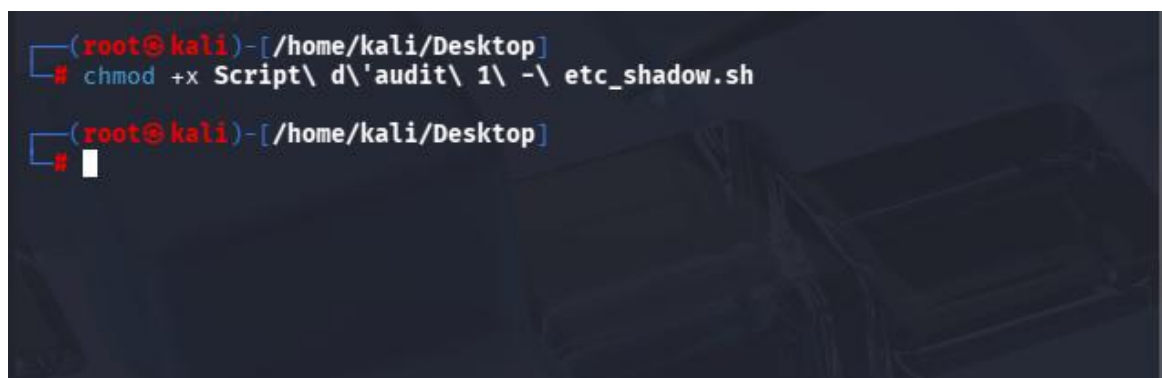
(root@kali)-[/home/kali/Desktop]
# ls
"Script d'audit 1 - etc_shadow.sh"

(root@kali)-[/home/kali/Desktop]
# stat -c "%a" /etc/shadow
644

(root@kali)-[/home/kali/Desktop]
#
```

Ensuite on doit rendre le fichier exécutable avec cette commande :

Chmod +x /Script\ d\ 'audit\ 1\ -\ etc_shadow.sh

A terminal window showing the execution of the 'chmod +x' command on the file 'Script\ d\'audit\ 1\ -\ etc_shadow.sh'.

```
(root@kali)-[/home/kali/Desktop]
# chmod +x Script\ d\'audit\ 1\ -\ etc_shadow.sh

(root@kali)-[/home/kali/Desktop]
#
```


Puis l'exécuter avec les droits sudo :

sudo. /Script\ d\ 'audit\ 1\ -\ etc_shadow.sh

```
(root@kali)-[/home/kali/Desktop]
# sudo ./Script\ d\ 'audit\ 1\ -\ etc_shadow.sh
===== Audit des permissions du fichier /etc/shadow =====

Permissions actuelles de /etc/shadow : 644

⚠ Vulnérabilité détectée : /etc/shadow a des permissions trop larges (644).
Tout utilisateur peut lire les hashes de mots de passe, ce qui représente un r
isque majeur pour la sécurité.

===== Audit terminé =====

(root@kali)-[/home/kali/Desktop]
#
```

Le script a détecté que /etc/shadow est lisible par tous, ce qui expose les hashes des mots de passe.

Implémentation de la deuxième vulnérabilité + : Tache cron :

Création du fichier vulnérable pour la tâche cron :

```
(root@kali)-[/home/kali/Desktop]
# sudo nano script_vuln_tcron.sh

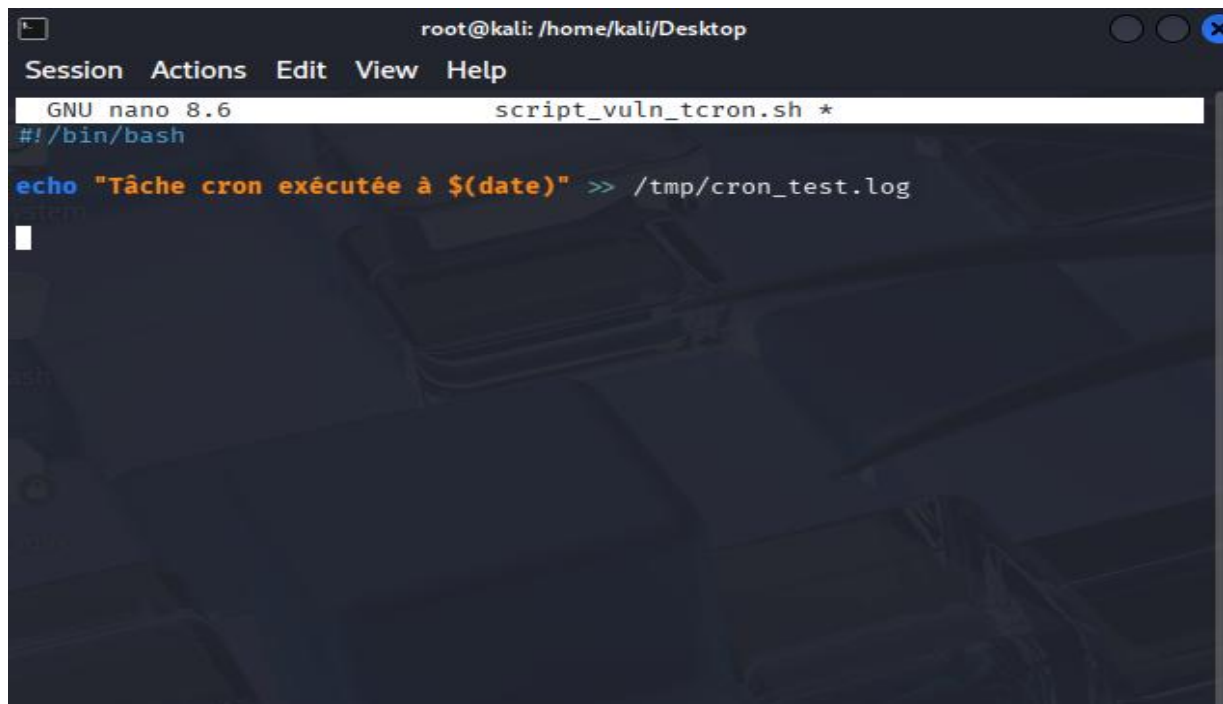
(root@kali)-[/home/kali/Desktop]
# ls
"Script d'audit 1 - etc_shadow.sh"  script_vuln_tcron.sh

(root@kali)-[/home/kali/Desktop]
# sudo nano script_vuln_tcron.sh
```

Entrer cette commande qui décrit ce que fera le script de la tâche cron lors de son exécution :

```
echo "Tâche cron exécutée à $(date)" >>
/tmp/cron_test.log
```

Cette commande nous indique le jour et la durée de l'exécution de la tâche cron.

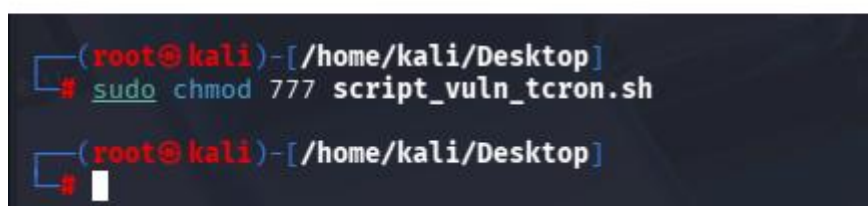


```
root@kali: /home/kali/Desktop
Session Actions Edit View Help
GNU nano 8.6 script_vuln_tcron.sh *
#!/bin/bash
echo "Tâche cron exécutée à $(date)" >> /tmp/cron_test.log
```

Ensuite, enregistrer soit avec **Ctrl + S** ou **Ctrl + O** puis quitter avec **Ctrl + X**

Ensuite, avant de pouvoir exécuter le fichier et procéder à son audit, nous devons le rendre exécutable en insérant cette commande :

sudo chmod 777 (la vulnérabilité est directement implémentée en donnant des droits trop élevés) : Tout le monde peut lire, écrire et exécuter le script.



```
(root@kali)-[/home/kali/Desktop]
# sudo chmod 777 script_vuln_tcron.sh
(root@kali)-[/home/kali/Desktop]
#
```

Toutefois `sudo chown root:root` indique au système que le script appartient l'administrateur (au root) :

```
(root@kali)-[/home/kali/Desktop]
# sudo chown root:root script_vuln_tcron.sh

(root@kali)-[~kali/Desktop]
#
```

Création de la tâche cron. Ensuite on sélectionne l'éditeur qu'on veut utiliser. Dans notre cas, c'est nano. Plus pertinent.

```
(root@kali)-[~kali/Desktop]
# sudo crontab -e
no crontab for root - using an empty one
Select an editor. To change later, run select-editor again.
 1. /bin/nano      ← easiest
 2. /usr/bin/vim.basic
 3. /usr/bin/vim.tiny

Choose 1-3 [1]: 1
crontab: installing new crontab

(root@kali)-[~kali/Desktop]
#
```

```
(root@kali)-[~kali/Desktop]
# ls -l /home/kali/Desktop/script_vuln_tcron.sh
-rwxrwxrwx 1 root root 77 Dec 22 06:33 /home/kali/Desktop/script_vuln_tcron.s
h

(root@kali)-[~kali/Desktop]
#
```

ls -l + chemin d'accès de notre script pour afficher les droits du script. On voit bien que le propriétaire, le groupe ainsi que tous les autres utilisateurs ont les mêmes droits. Des droits root ce qui est énormément dangereux car dans ce cas le root ne sert plus à rien en fait et le fichier est plus qu'exposer.

Lors d'une attaque, le root pourrait ne plus jamais pouvoir accéder à nouveau à ce fichier si l'attaquant lui retire ses droits en tant root utilisateur.

Ensuite on affiche le contenu de la tâche cron :

La tâche cron a été configurée de telle sorte qu'elle nous rende un audit chaque minutes.

```
(root@kali)-[~kali/Desktop]
# cat /tmp/cron_test.log
Tâche cron exécutée à Mon Dec 22 09:49:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 09:50:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 09:51:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 09:52:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 09:53:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 09:54:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 09:55:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 09:56:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 09:57:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 09:58:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 09:59:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:00:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:01:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:02:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:03:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:04:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:05:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:06:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:07:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:08:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:09:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:10:01 AM EST 2025
Tâche cron exécutée à Mon Dec 22 10:11:01 AM EST 2025
```

```
root@kali: ~kali/Desktop
Session Actions Edit View Help
GNU nano 8.6 /tmp/crontab.rYHIW0/crontab
# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').
#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h dom mon dow  command
* * * * * /home/kali/Desktop/script_vuln_tcron.sh
```

Les astérisques représentent le nombre de minutes.

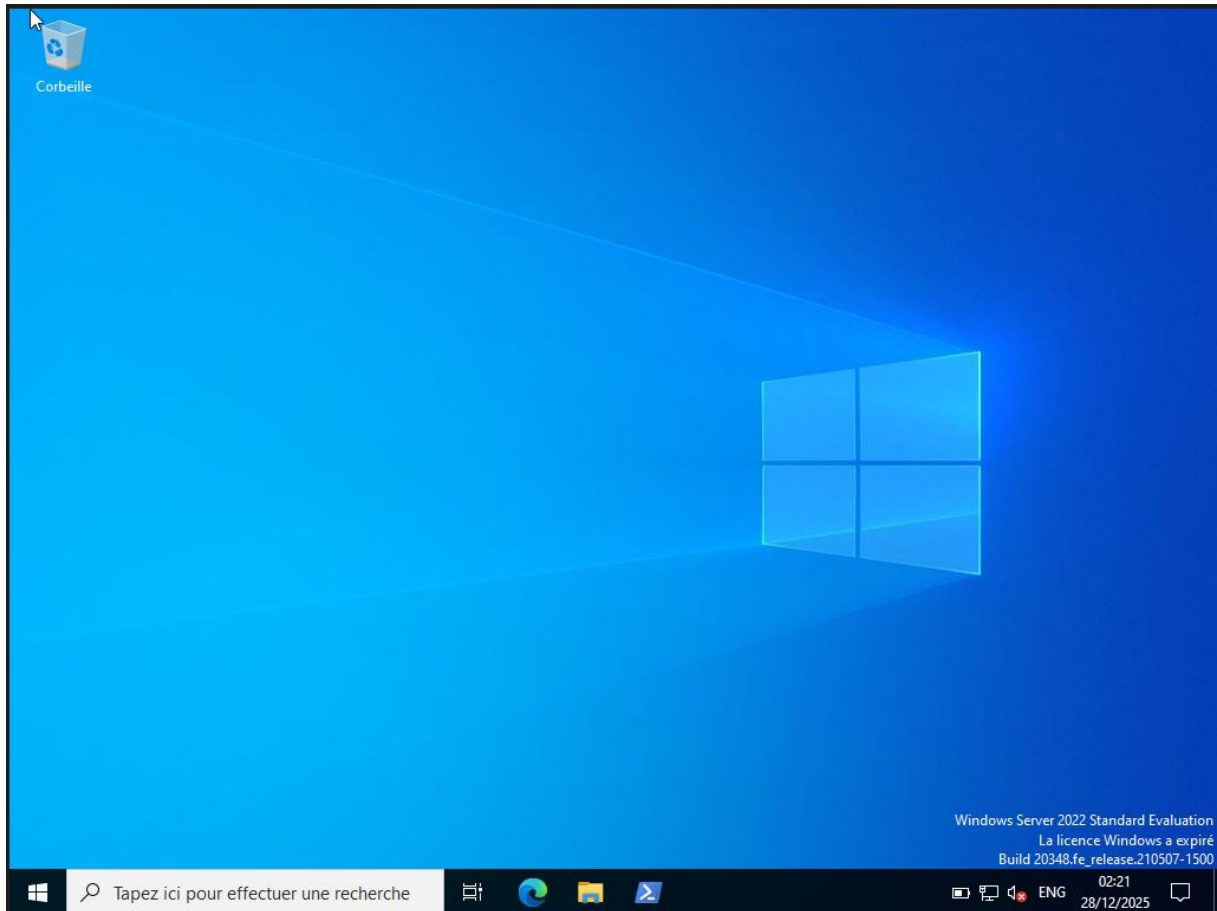
Si nous ne voulons plus que la tâche cron ne s'exécute plus, il suffit de mettre un # au début de la ligne.

Dans le cas où on voudrait carrément supprimer les tâches cron, il faudra exécuter cette commande :

`sudo crontab -r` . « Sudo » car nous sommes root.

Implémentation de vulnérabilités sur la VM

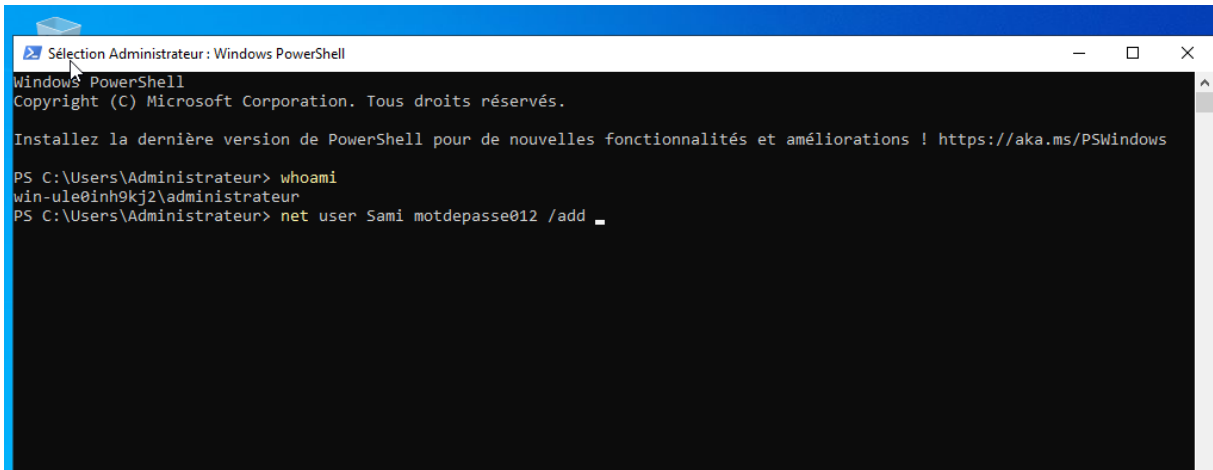
Windows



Implémentation de la première vulnérabilité depuis l'invite de commande (PowerShell) : Nouvel utilisateur avec mot de passe faible

Tout d'abord, on s'assure qu'on soit administrateur afin d'avoir tous droits nécessaires en rentrant la commande :
« **whoami** »

Ensuite, on crée un nouvel utilisateur et un mot de passe faible.



```
Sélection Administrateur : Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. Tous droits réservés.

Installez la dernière version de PowerShell pour de nouvelles fonctionnalités et améliorations ! https://aka.ms/PSWindows

PS C:\Users\Administrateur> whoami
win-ule0inh9kj2\Administrateur
PS C:\Users\Administrateur> net user Sami motdepasse012 /add
```

Le nom de l'utilisateur dans ce cas est : **Sami**

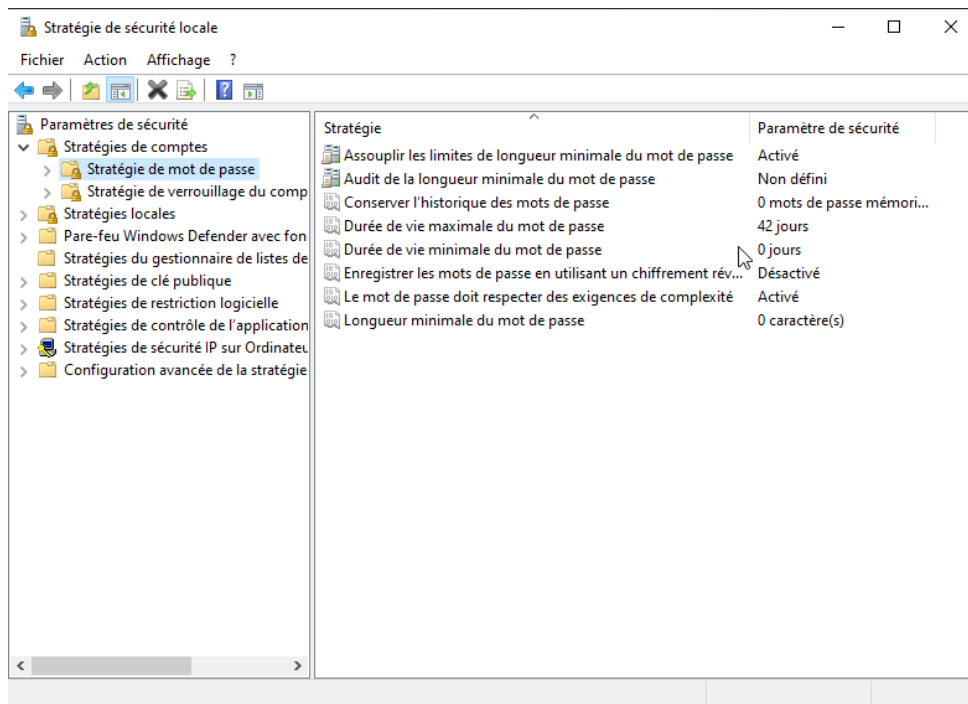
Le mot de passe est : **motdepasse012**

Il est fort probable que les normes de sécurité de votre machine virtuelle Windows empêchant l'implémentation de la première vulnérabilité.

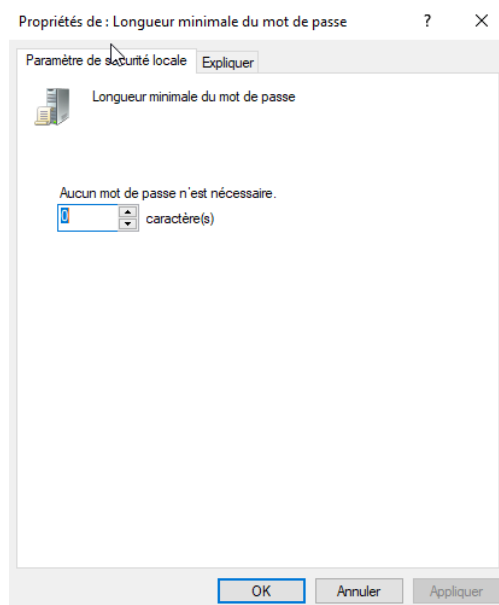
Pour contourner cela, vous devez donc faire ceci :

Assouplir la stratégie de mot de passe

Dû au fait que la rigidité stratégie de mot de passe de Windows, ne nous permettait pas d'implémenter la vulnérabilité, nous avons dû assouplir la stratégie de mot de passe en accédant à l'outil de stratégie de sécurité locale.

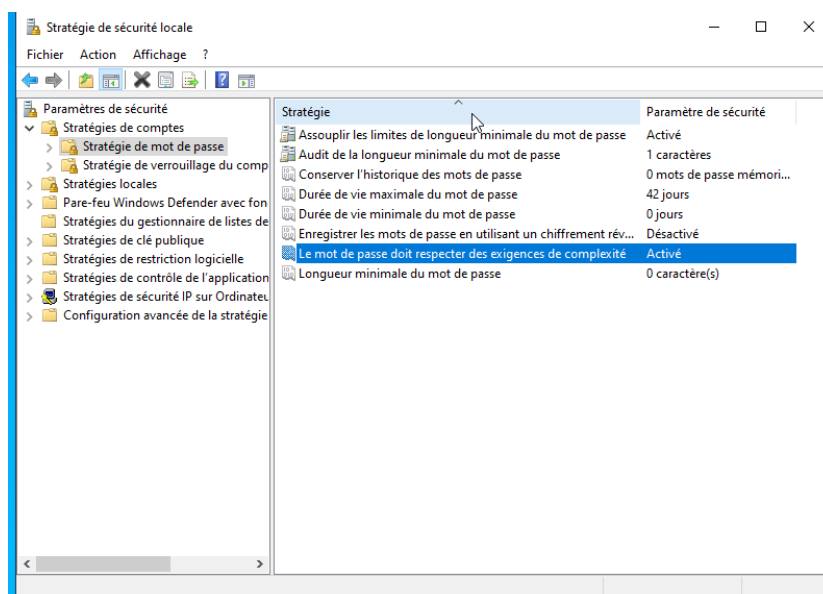


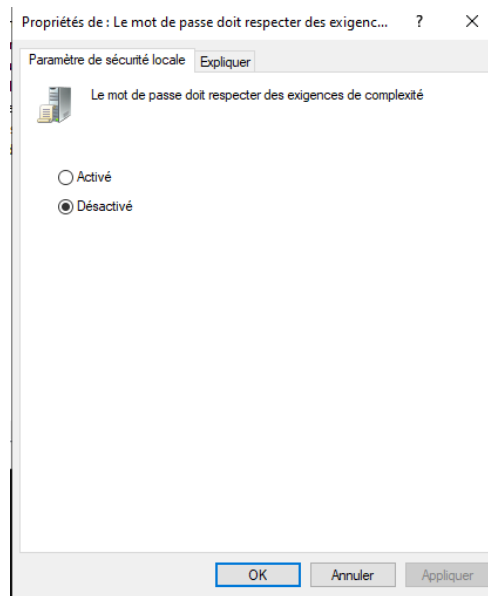
Modification de la longueur minimale du mot de passe :



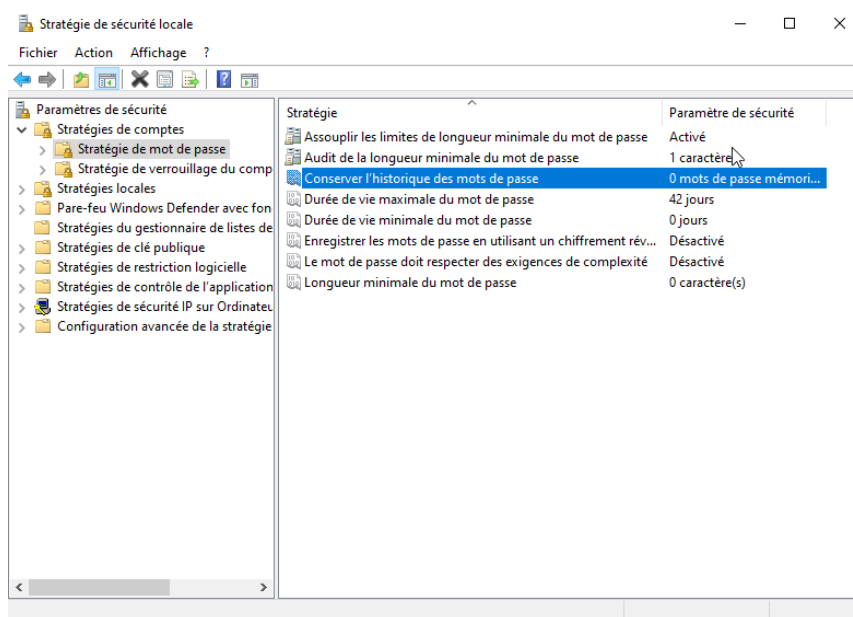
Le fait de mettre 0 nous permettra de mieux exploiter la vulnérabilité sans aucune limitation.

Désactiver aussi les contraintes d'exigence de complexité :





La conservation de l'historique des mots de passe doit être configuré sur 0 afin de permettre l'utilisation de divers mots de passe :



Après ces configurations, entrer à nouveau la commande pour création d'utilisateur et de mot de passe :

<< net user nom utilisateur mot de passe /add >>

```
PS C:\Users\Administrateur> net user Sami motdepasse012 /add
La commande s'est terminée correctement.
PS C:\Users\Administrateur>
```

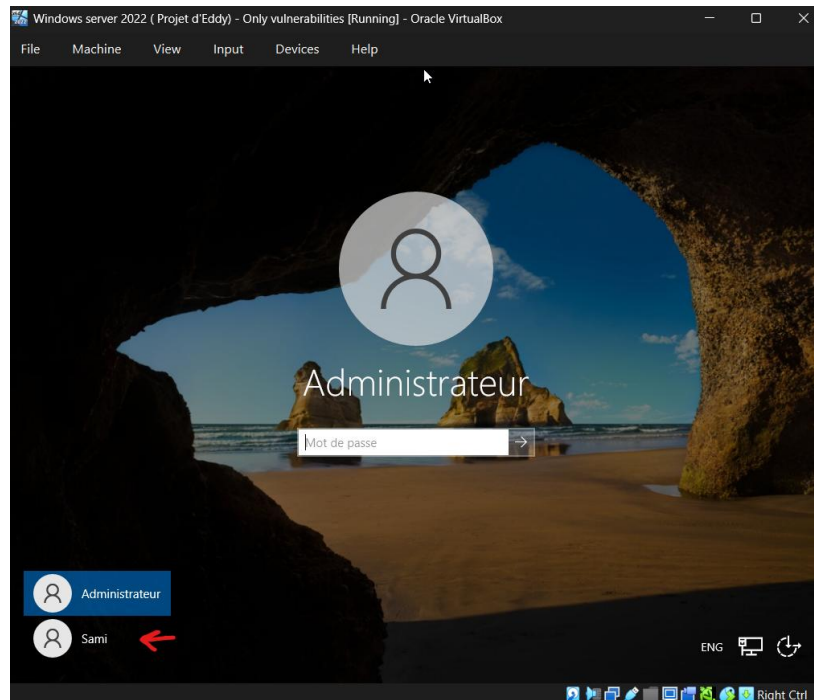
Cela fonctionne maintenant.

Nous pouvons vérifier que l'utilisateur a bien été créé en rentrant cette commande : **net user**

```
PS C:\Users\Administrateur> net user
comptes d'utilisateurs de \\WIN-ULE0INH9KJ2
-----
Administrateur      DefaultAccount      Invité
Sami                WDAGUtilityAccount
La commande s'est terminée correctement.
PS C:\Users\Administrateur>
```

Implémentation de la première vulnérabilité Windows réussie.

L'utilisateur a bien été créé :



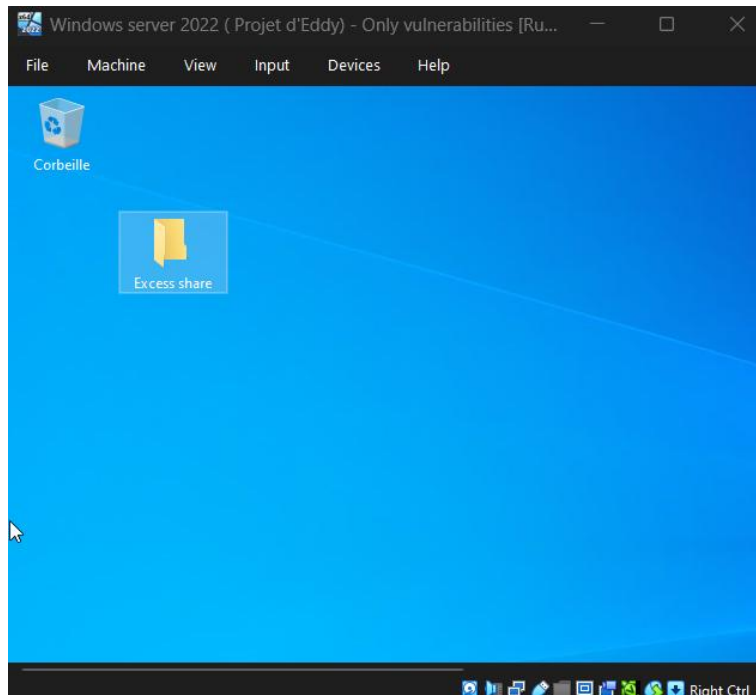
Cette vulnérabilité laisse un accès facile aux attaquants car le mot de passe est faible et donc facilement devinable ou cassable par attaque par dictionnaire/force brute .

Un attaquant pourra donc accéder au système avec ce compte et voler, modifier des données, installer des malwares ou utiliser la machine comme point d'entrée pour attaquer d'autres systèmes.

Implémentation de la deuxième vulnérabilité :

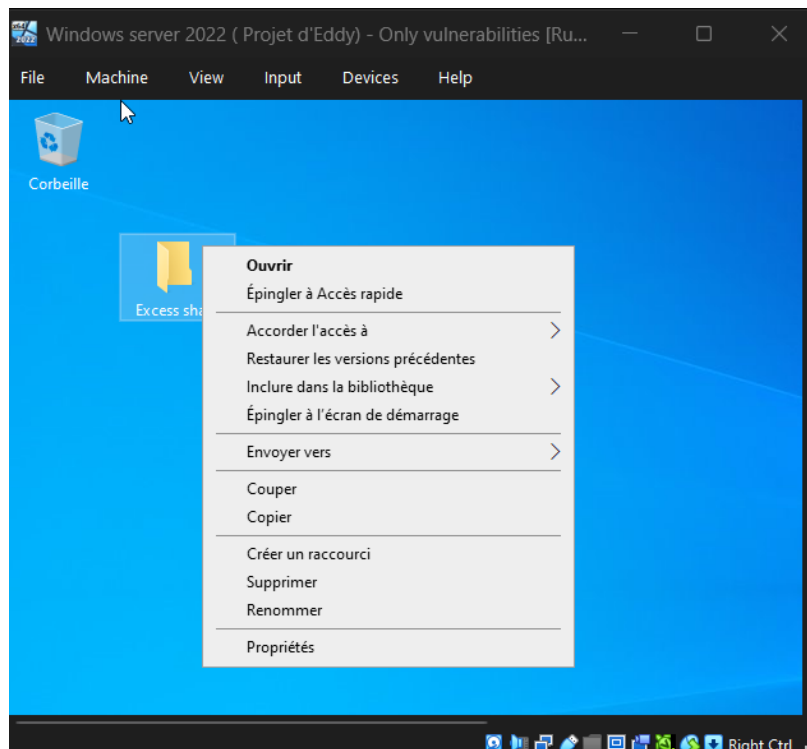
Partage réseau trop permissif depuis un dossier.

Création du dossier avec le nom « Excess share »

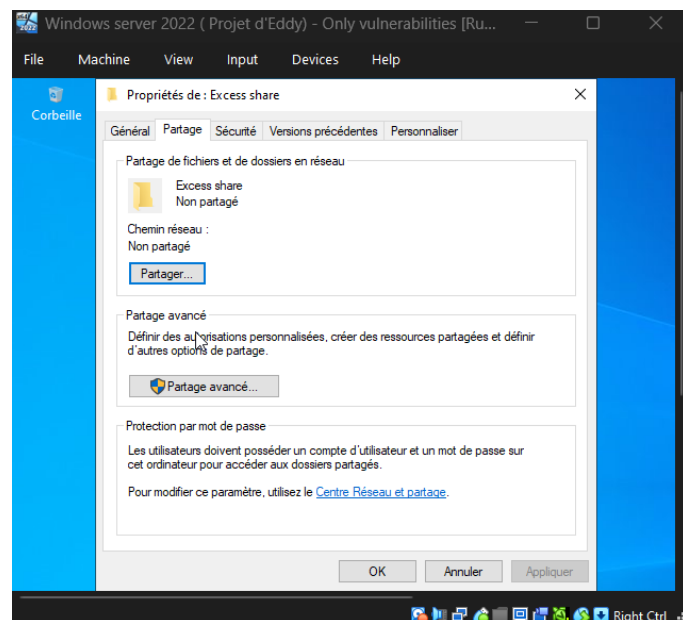


Activation du partage dossier depuis l'onglet partage :

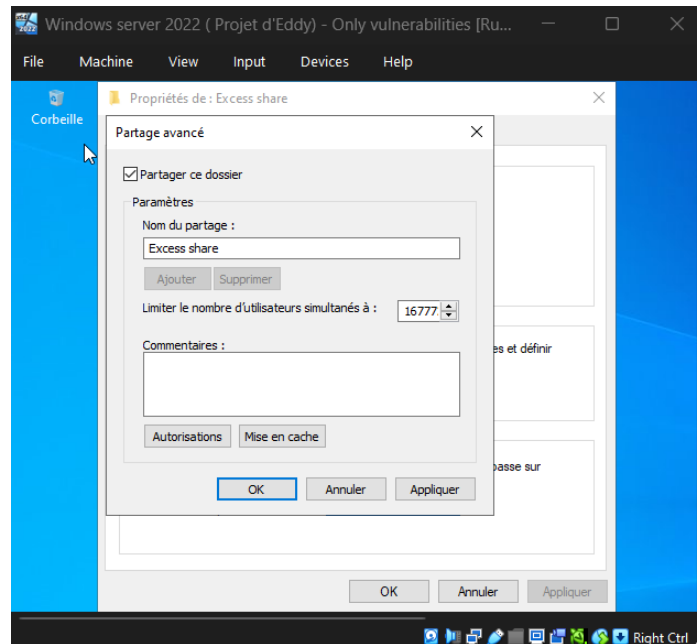
- Cliquez droite sur le dossier



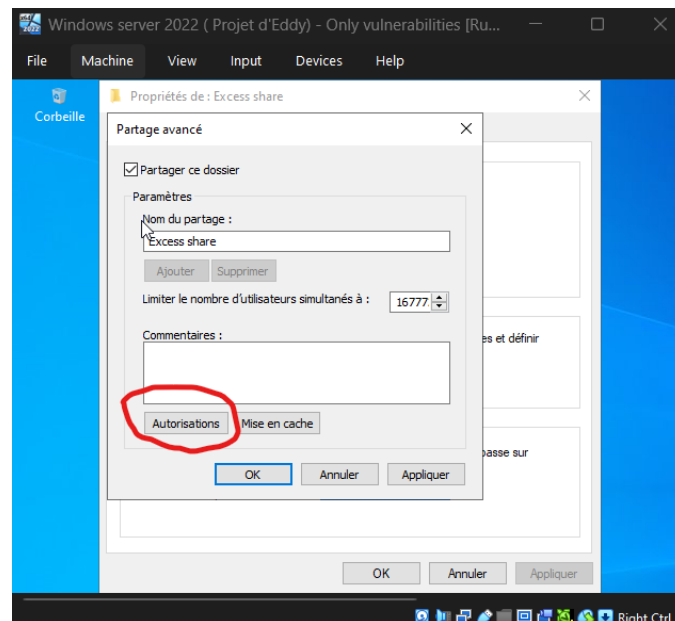
- propriétés
- cliquer sur partage avancée



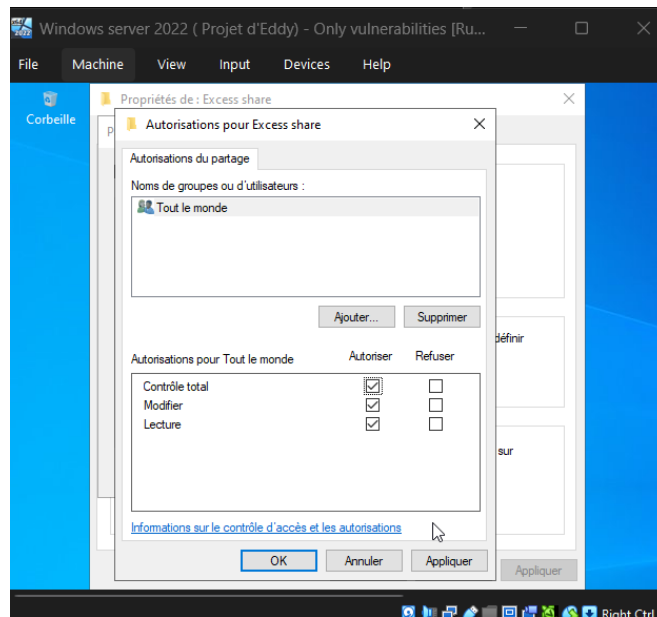
- Cocher partager ce dossier



- Autorisations se dégrise, cliquer sur autorisations



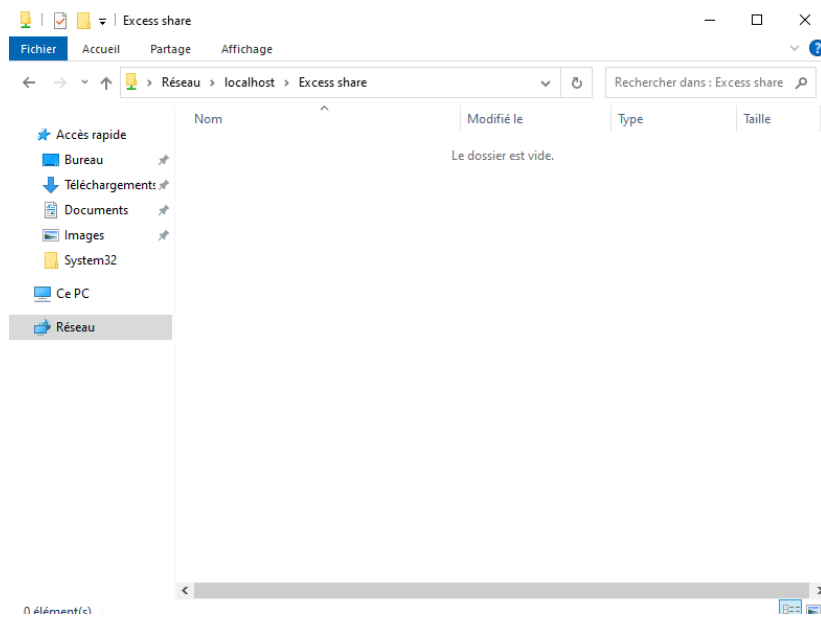
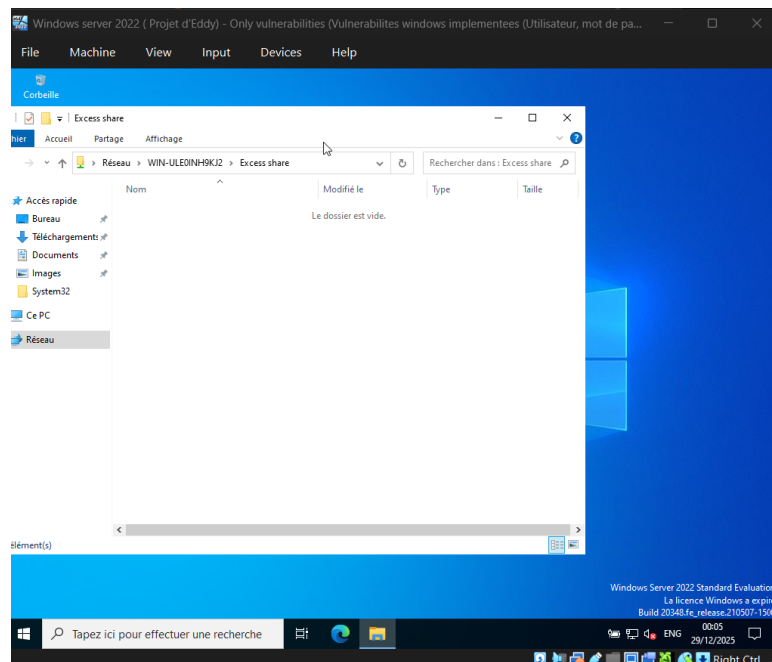
- Cocher contrôle total dans la colonne Autoriser et cliquer sur Ok



Par la suite, on peut vérifier l'accès au dossier depuis notre ordinateur en rentrant son chemin d'accès dans la barre de l'explorateur de fichiers :

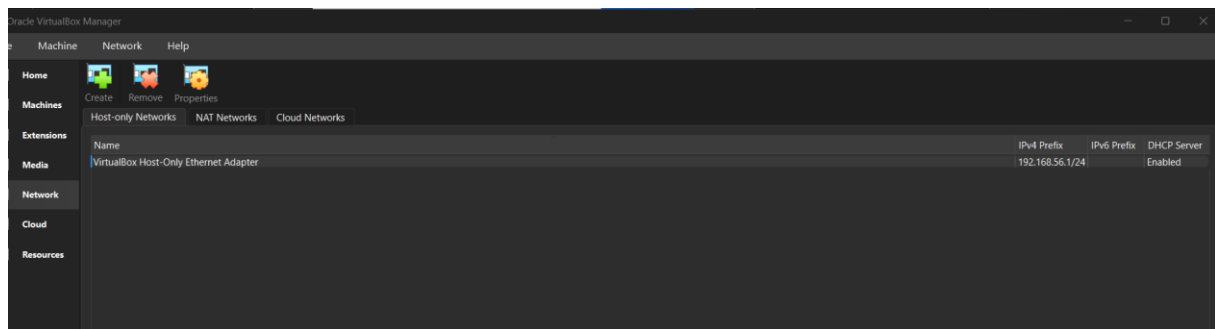
Commande utilisée: \\WIN-ULE0INH9KJ2\Excess share

Ou \\localhost\Excess share



On pourrait aussi y accéder en utilisant l'adresse ip de notre machine virtuelle. Dans notre cas, l'adresse est :

192.168.56.1/24



Cependant, le dossier n'a été configuré de telle sorte qu'il ne soit accessible que depuis un même réseau et pas un réseau extérieur.

Dans notre cas, nous avons accédé au dossier depuis l'appareil sur lequel se trouve le dossier.

Dans le cas où on voudrait y accéder depuis un autre appareil, il faudra être connecté au même réseau sur lequel se trouve le dossier.

D'autre part, si nous voulons vérifier que le dossier est bien actif. Nous pouvons entrer cette commande depuis la cli : **net share** qui affichera tous les partages actifs

```
Sélection Administrateur : Windows PowerShell

PS C:\Users\Administrateur> net share

Nom partage  Ressource                                Remarque
-----
C$           C:\                                     Partage par défaut
IPC$         C:\                                     IPC distant
ADMIN$       C:\Windows                             Administration à distance
Excess share C:\Users\Administrateur\Desktop\Excess share

La commande s'est terminée correctement.
```

Cette vulnérabilité laisse des droits excessifs à l'utilisateur sur le dossier partage.

Cela laissera un vaste champ aux attaquants et entraînerait une fuite de données sensibles, suppression ou ajout de fichiers dans le dossier partage.

SURVEILLANCE DES JOURNAUX ET ALERTES

Partie Linux

Journal à surveiller :

/etc/shadow (permissions trop larges)

Nous voulons surveiller les **tentatives de lecture ou de modification** de **/etc/shadow** par des utilisateurs non autorisés ; les **messages de permission ou d'authentification liés au fichier** et les **commandes suspectes** comme « cat, cp, etc »

Le script de surveillance devrait nous envoyer des mails et une alerte à temps réel à chaque fois qu'un accès ou une tentative suspecte serait détectée.

Généralement les évènements ou diverses actions sont enregistrés dans **/var/log/auth.log** sur Kali

Dans le cas où les logs ne sont pas installés, il faut d'abord mettre à jour la liste des logiciels disponible sur la distribution Linux afin qu'elle soit optimisée en utilisant la commande :
sudo apt update

Ensuite vérifier avec un **ls /var/log/auth.log** son existence.

S'il n'y est pas, l'installe avec la commande : **sudo apt install rsyslog**

Ensuite, activer l'outil :

sudo systemctl enable rsyslog

Et le lancer :

sudo systemctl start rsyslog

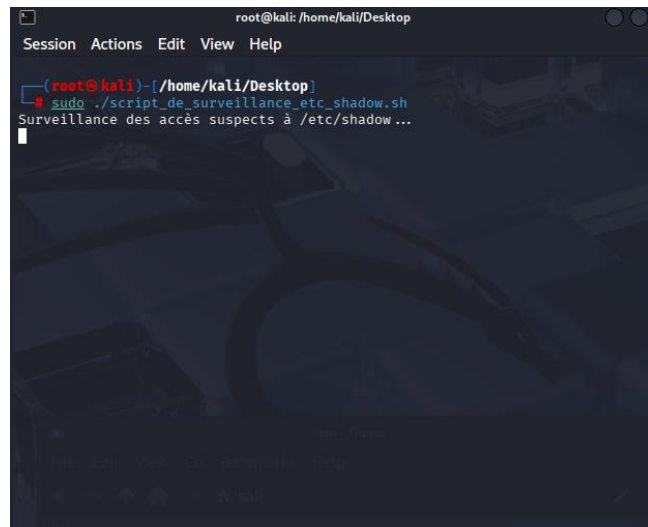
Lorsque tout est opérationnel, vérifier la présence de l'outil **mail** car c'est cet outil qui va permettre au script de surveillance de nous envoyer des mails en cas de suspicion sur le système

Dans le cas où il n'y est pas, l'installe :

sudo apt install mailutils

Nous pouvons maintenant procéder au test :

Lancer le script de surveillance du fichier en tant que **root**.

A screenshot of a terminal window with a dark background. The window title is 'root@kali: /home/kali/Desktop'. The menu bar shows 'Session', 'Actions', 'Edit', 'View', and 'Help'. The prompt is '(root@kali)-[/home/kali/Desktop]'. The command entered is '# sudo ./script_de_surveillance_etc_shadow.sh'. The output is 'Surveillance des accès suspects à /etc/shadow...'.

```
root@kali: /home/kali/Desktop
Session Actions Edit View Help
(root@kali)-[/home/kali/Desktop]
# sudo ./script_de_surveillance_etc_shadow.sh
Surveillance des accès suspects à /etc/shadow...
```

Par la suite, essayer d'afficher le contenu du fichier depuis un autre terminal avec la commande **cat** :

```
kali@kali: ~  
Session Actions Edit View Help  
kali@kali ~  
$ cat /etc/shadow  
root:*:20425:0:99999:7:::  
daemon:*:20425:0:99999:7:::  
bin:*:20425:0:99999:7:::  
sys:*:20425:0:99999:7:::  
sync:*:20425:0:99999:7:::  
games:*:20425:0:99999:7:::  
man:*:20425:0:99999:7:::  
lp:*:20425:0:99999:7:::  
mail:*:20425:0:99999:7:::  
news:*:20425:0:99999:7:::  
uucp:*:20425:0:99999:7:::  
proxy:*:20425:0:99999:7:::  
www-data:*:20425:0:99999:7:::  
backup:*:20425:0:99999:7:::  
list:*:20425:0:99999:7:::  
irc:*:20425:0:99999:7:::  
_apt:*:20425:0:99999:7:::  
nobody:*:20425:0:99999:7:::  
systemd-networkd:*:20425:0:99999:7:::  
dhcpcd:*:20425:0:99999:7:::  
systemd-timesyncd:*:20425:0:99999:7:::  
messagebus:*:20425:0:99999:7:::  
tss:*:20425:0:99999:7:::  
strongswan:*:20425:0:99999:7:::  
tcpdump:*:20425:0:99999:7:::  
sshd:*:20425:0:99999:7:::
```

Cela a marché.

On vérifie si on a reçu un mail avec la commande : **mail**

```
root@kali: /home/kali/Desktop  
Session Actions Edit View Help  
root@kali: /home/kali/Desktop  
$ sudo ./script_de_surveillance_etc_shadow.sh  
Surveillance des accès suspects à /etc/shadow...  
mail  
^Z  
zsh: suspended sudo ./script_de_surveillance_etc_shadow.sh  
root@kali: /home/kali/Desktop  
$ mail  
No mail for root  
root@kali: /home/kali/Desktop  
$
```

On constate qu'on n'a rien reçu et c'est dû au fait que le fichier **/etc/shadow** a des droits de permissions trop large et n'importe qui peut y accéder ce qui a fait que le système n'a

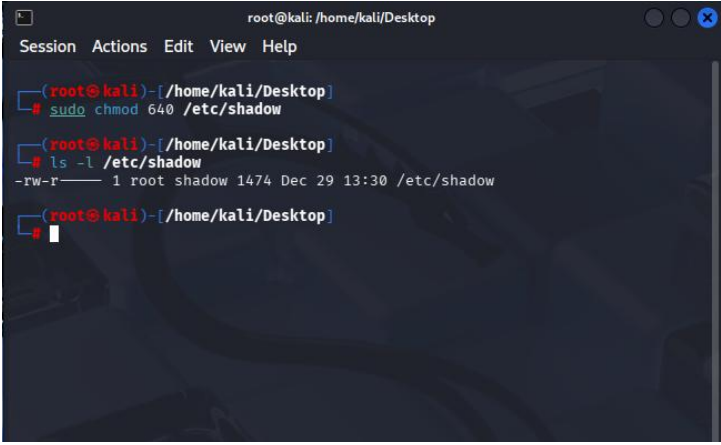
détecter aucune intrusion, c'est comme si cela était normal pour lui or ça ne l'est pas.

Cela confirme une fois de plus la criticité et la dangerosité de la vulnérabilité implémenté au fichier plutôt dans le projet.

Dans le cas où le fichier `/etc/shadow` a des droits restreints, voilà ce qui se produirait :

Tout d'abord, on réduit les droits :

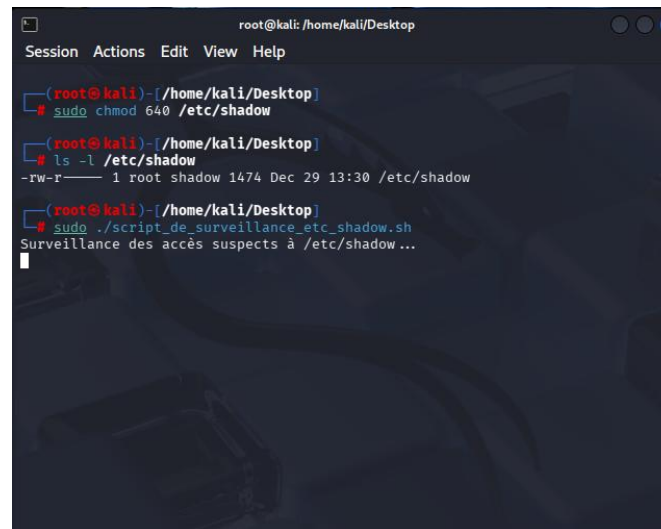
Sudo chmod 640 pour réduire les droits excessifs attribue au fichier dans la partie implémentation de vulnérabilités.

A terminal window titled 'root@kali: /home/kali/Desktop' with a menu bar (Session, Actions, Edit, View, Help). The terminal shows the following commands and output:

```
(root@kali)-[/home/kali/Desktop]
# sudo chmod 640 /etc/shadow
(root@kali)-[/home/kali/Desktop]
# ls -l /etc/shadow
-rw-r----- 1 root shadow 1474 Dec 29 13:30 /etc/shadow
(root@kali)-[/home/kali/Desktop]
#
```

Le fichier passe donc des droits 644 à 640

Ensuite lancer le `./script_de_surveillance` :



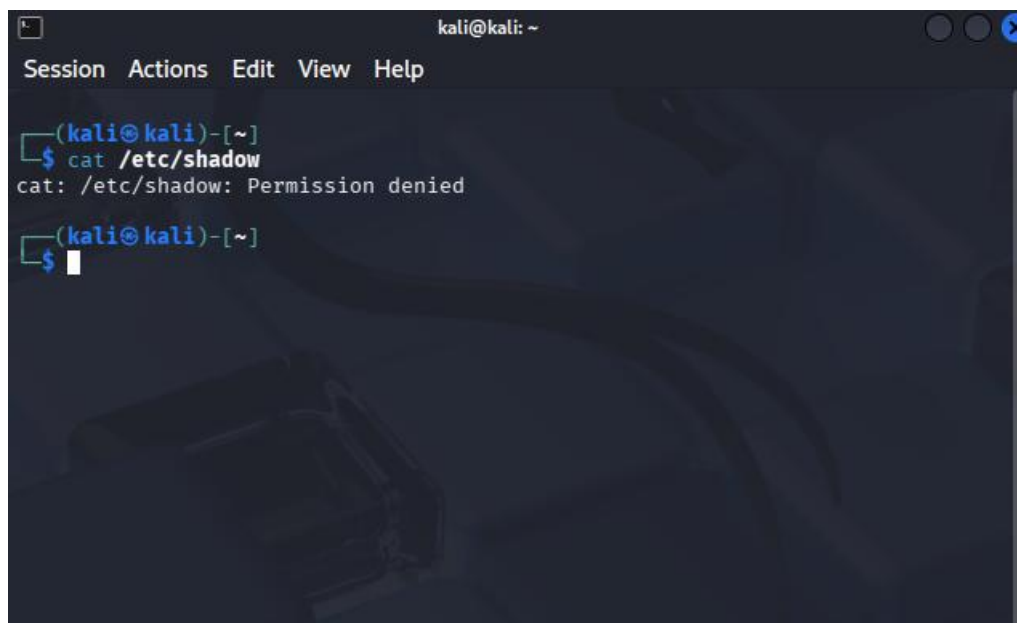
```
root@kali: /home/kali/Desktop
Session Actions Edit View Help

(root@kali)-[/home/kali/Desktop]
# sudo chmod 640 /etc/shadow

(root@kali)-[/home/kali/Desktop]
# ls -l /etc/shadow
-rw-r----- 1 root shadow 1474 Dec 29 13:30 /etc/shadow

(root@kali)-[/home/kali/Desktop]
# sudo ./script_de_surveillance_etc_shadow.sh
Surveillance des accès suspects à /etc/shadow ...
```

Depuis un autre terminal, essayer d’afficher le contenu du fichier avec la commande `cat` :



```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ cat /etc/shadow
cat: /etc/shadow: Permission denied

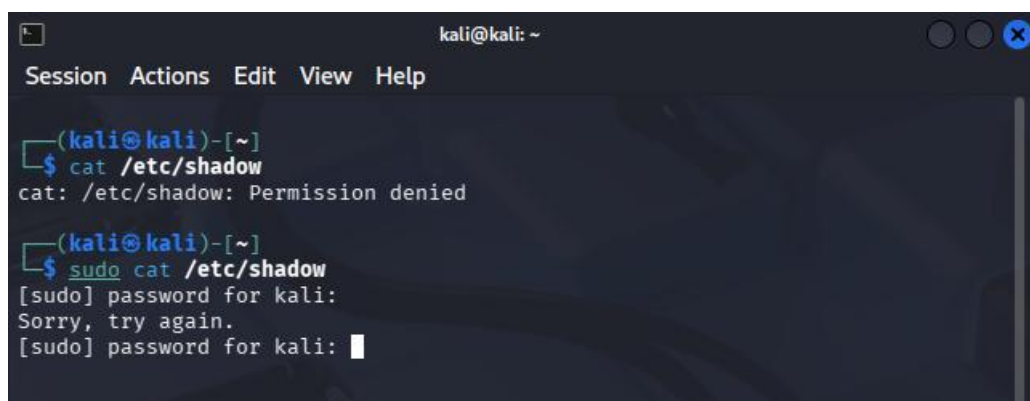
(kali@kali)-[~]
$
```

Le fichier /etc/shadow a bien **des permissions sécurisées (640)**. L'utilisateur kali reçoit une **erreur "Permission denied"** donc la protection système fonctionne. Le script de surveillance s'exécute correctement et ne plante pas.

Cependant aucune alerte n'a été envoyée car la tentative d'accès a échoué dans le terminal avant même d'être écrite dans le log donc le script n'a pas vu d'évènement se produire.

Alternative : Forcer une trace dans le log en utilisant la commande **sudo**

Dans l'autre terminal, tenter un accès au fichier /etc/shadow et erroné exprès le mot de passe pour recevoir une alerte sur le terminal du root.



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ cat /etc/shadow  
cat: /etc/shadow: Permission denied  
(kali@kali)-[~]  
$ sudo cat /etc/shadow  
[sudo] password for kali:  
Sorry, try again.  
[sudo] password for kali: 
```

```
root@kali: /home/kali/Desktop
Session Actions Edit View Help

(root@kali)-[/home/kali/Desktop]
# sudo chmod 640 /etc/shadow

(root@kali)-[/home/kali/Desktop]
# ls -l /etc/shadow
-rw-r----- 1 root shadow 1474 Dec 29 13:30 /etc/shadow

(root@kali)-[/home/kali/Desktop]
# sudo ./script_de_surveillance_etc_shadow.sh
Surveillance des accès suspects à /etc/shadow...
2026-01-03T15:41:24.479296-05:00 kali sudo: pam_unix(sudo:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/2 ruser=kali rhost= user=kali
Alerte envoyée par mail local !
```

Motif d'évènement : Connexion échoué (tentative d'accès échoué)

Dans une vraie situation où un individu tenterait d'accéder à un fichier sécurisé auquel n'a accès que le root, voilà ce qui se produira. L'individu ne saura pas que le root a été informé et sait qu'il y'a eu une tentative d'intrusion.

Deuxième journal à surveillé :

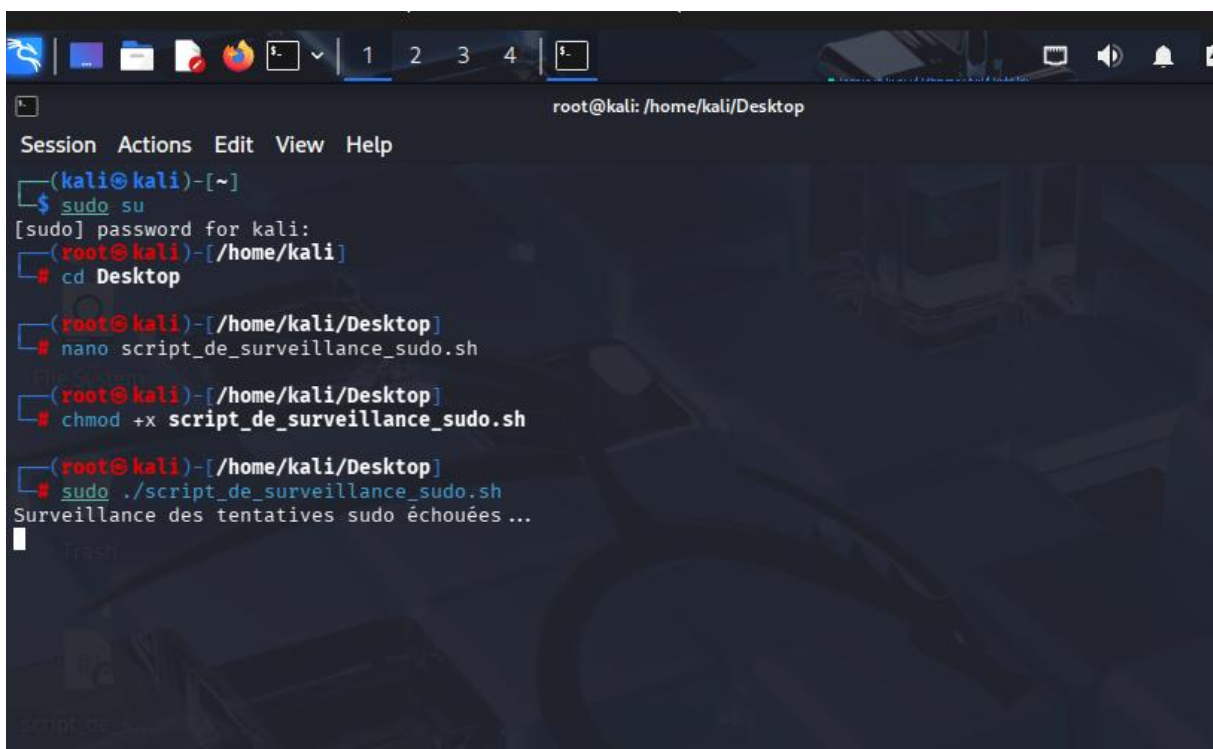
Tentatives sudo réussies ou échouées

Créer le script : **script_de_surveillance_sudo.sh**

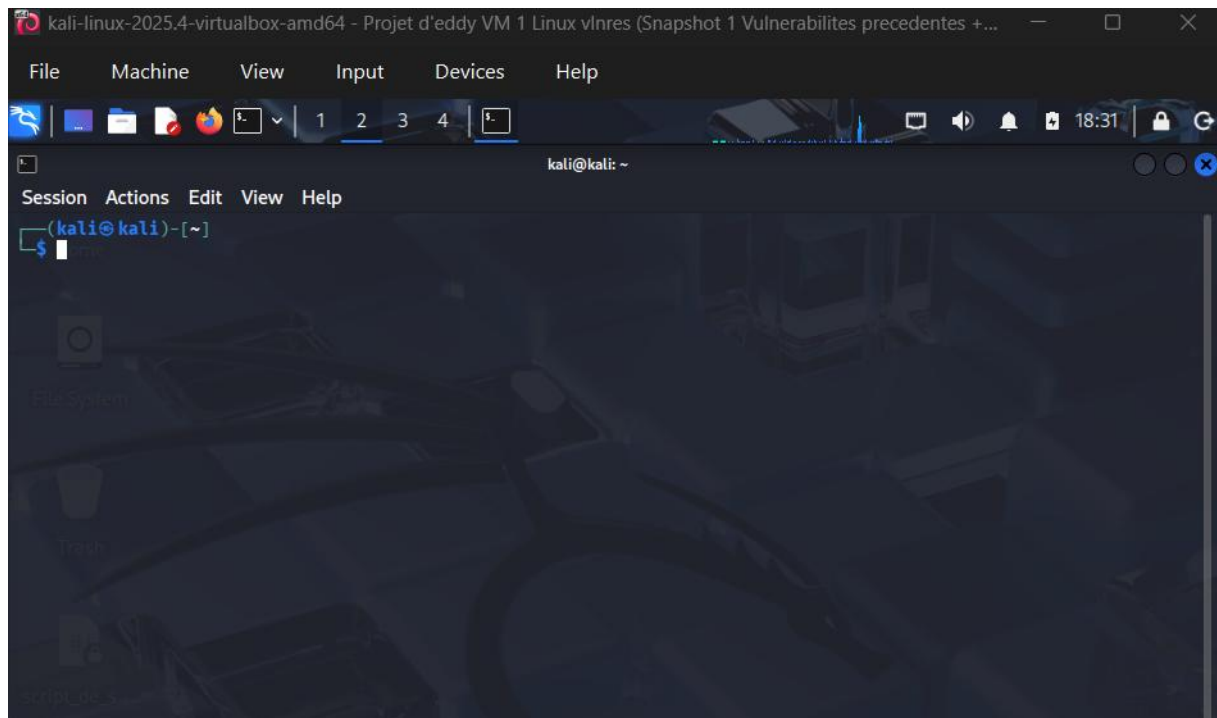
Ensuite, attribuer les droits d'exécution : **chmod +x**

Lancer le script : **sudo**

./script_de_surveillance_sudo.sh

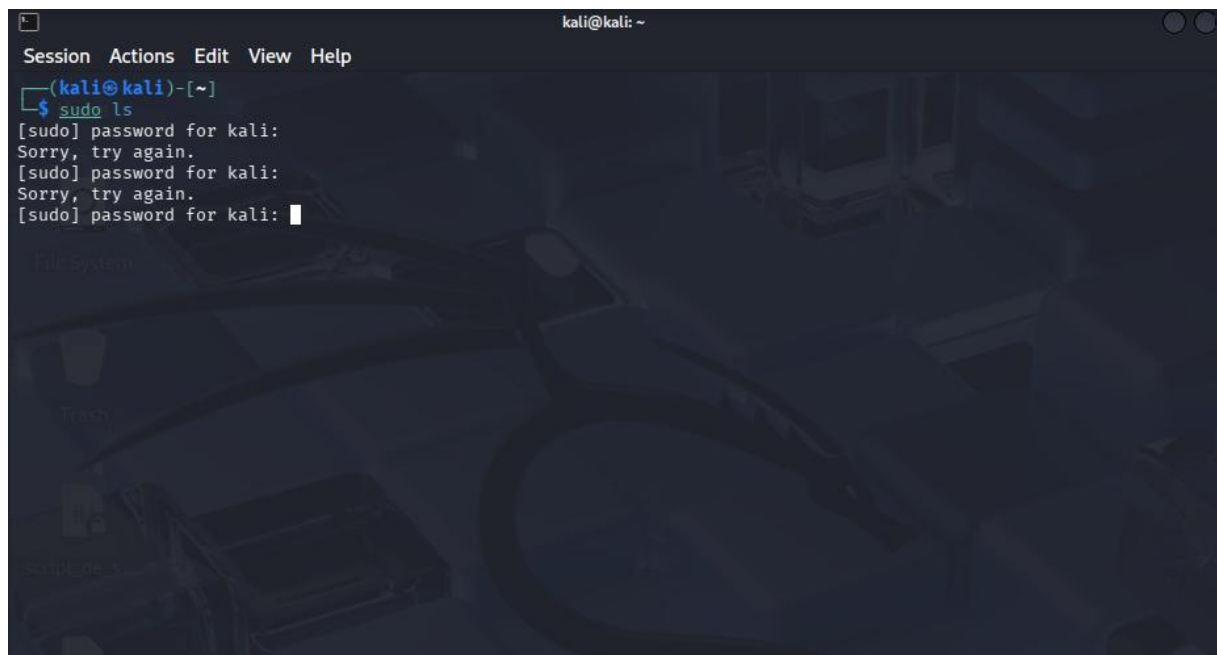
A screenshot of a terminal window on a Kali Linux desktop. The window title is 'root@kali: /home/kali/Desktop'. The terminal shows a sequence of commands and their outputs: 1. User is in a shell as 'kali' at '~'. 2. Command: `sudo su`. Output: `[sudo] password for kali:` followed by a prompt. 3. Prompt changes to `(root@kali)-[/home/kali]`. 4. Command: `cd Desktop`. 5. Prompt changes to `(root@kali)-[/home/kali/Desktop]`. 6. Command: `nano script_de_surveillance_sudo.sh`. 7. Command: `chmod +x script_de_surveillance_sudo.sh`. 8. Command: `sudo ./script_de_surveillance_sudo.sh`. 9. Output: `Surveillance des tentatives sudo échouées ...`. The terminal has a dark theme with a Kali Linux logo in the background. The desktop environment shows a taskbar with various icons at the top and a trash icon at the bottom left.

Ouvrir un autre terminal :

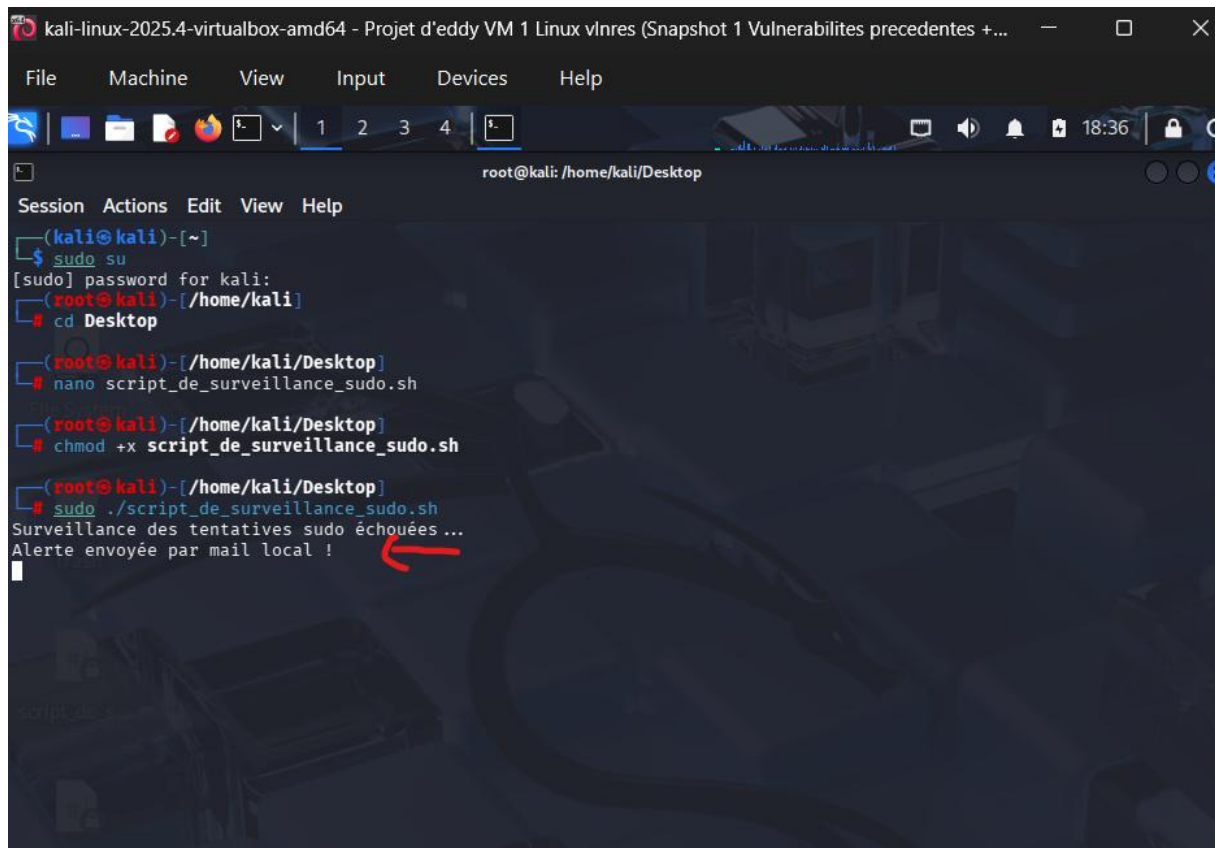


Sudo ls :

Entrez plusieurs mots de passe erroné :



Le script de surveillance a détecté les tentatives d'accès et a envoyé un mail d'alerte :



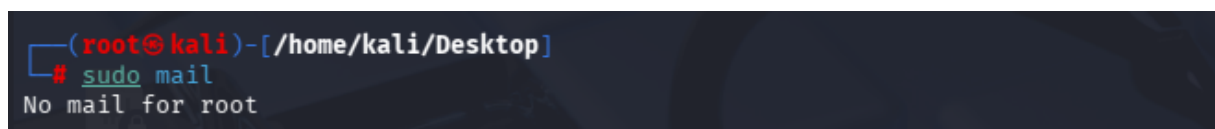
```
kali-linux-2025.4-virtualbox-amd64 - Projet d'eddy VM 1 Linux vinres (Snapshot 1 Vulnerabilites precedentes +...
File Machine View Input Devices Help
1 2 3 4
root@kali: /home/kali/Desktop
Session Actions Edit View Help
(kali@kali)-[~]
└─$ sudo su
[sudo] password for kali:
(root@kali)-[/home/kali]
└─# cd Desktop

(root@kali)-[/home/kali/Desktop]
└─# nano script_de_surveillance_sudo.sh

(root@kali)-[/home/kali/Desktop]
└─# chmod +x script_de_surveillance_sudo.sh

(root@kali)-[/home/kali/Desktop]
└─# sudo ./script_de_surveillance_sudo.sh
Surveillance des tentatives sudo échouées ...
Alerte envoyée par mail local !
```

Aucun mail trouve



```
(root@kali)-[/home/kali/Desktop]
└─# sudo mail
No mail for root
```

Le script fonctionne bien, il a affiché « Alerte envoyée par mail local ! », donc la détection et la logique d'envoi étaient correctes. Cependant le système n'a pas livré le message dans la boîte locale ce qui signifie que « mailutils » mais aucun agent de transfert local ne prenait en charge le message sur la VM.

De manière générale, sur Kali et certaines Ubuntu minimalistes, mailutils est installé sans service de transfert local (comme Postfix, Exim ou SSMTP).

Résultat : la commande mail s'exécute, mais aucun message ne s'écrit dans /var/mail/root.

Nous avons donc essayé d'installer l'agent minimal avec cette commande :

```
sudo apt install postfix -y
```



```
(root@kali)-[/home/kali/Desktop]
# sudo apt install postfix -y
Installing:
postfix

Installing dependencies:
libtlsrpt0

Suggested packages:
postfix-cdb postfix-lmdb postfix-mysql postfix-sqlite sasl2-bin
postfix-doc postfix-mta-sts-resolver postfix-pcre procmail | dovecot-common
postfix-ldap postfix-mongodb postfix-pgsql resolvconf ufw

REMOVING:
exim4-base exim4-config exim4-daemon-light

Summary:
Upgrading: 0, Installing: 2, Removing: 3, Not Upgrading: 757
Download size: 1,612 kB
Freed space: 157 kB

Get:2 http://archive-4.kali.org/kali kali-rolling/main amd64 postfix amd64 3.10.6-1 [1,602 kB]
Get:1 http://kali.download/kali kali-rolling/main amd64 libtlsrpt0 amd64 0.5.0.-1 [10.2 kB]
Fetched 1,612 kB in 22s (74.8 kB/s)
Preconfiguring packages ...
(Reading database ... 423363 files and directories currently installed.)
Removing exim4-daemon-light (4.99.1-1) ...
Removing exim4-base (4.99.1-1) ...
Removing exim4-config (4.99.1-1) ...
Selecting previously unselected package libtlsrpt0:amd64.
(Reading database ... 423228 files and directories currently installed.)
Preparing to unpack .../libtlsrpt0_0.5.0.-1_amd64.deb ...
Unpacking libtlsrpt0:amd64 (0.5.0.-1) ...
Selecting previously unselected package postfix.
Preparing to unpack .../postfix_3.10.6-1_amd64.deb ...
Unpacking postfix (3.10.6-1) ...
Setting up libtlsrpt0:amd64 (0.5.0.-1) ...
Setting up postfix (3.10.6-1) ...
update-rc.d: As per Kali policy, postfix init script is left disabled.
Creating /etc/postfix/dynamicmaps.cf
setting myhostname: kali.lan
setting alias maps
setting alias database
mailname is not a fully qualified domain name. Not changing /etc/mailname.
setting destinations: $myhostname, kali, localhost.localdomain, localhost
setting relayhost:
setting mynetworks: 127.0.0.0/8 [::ffff:127.0.0.0]/104 [::1]/128
clearing mailbox_command
setting mailbox_size_limit: 0
setting recipient_delimiter: +
```

```
setting recipient_delimiter: +
setting inet_interfaces: loopback-only
setting default_transport: error
setting relay_transport: error
setting inet_protocols: all
WARNING: /etc/aliases exists, but does not have a root alias.

Postfix (main.cf) is now set up with a default configuration. If you need to
make changes, edit /etc/postfix/main.cf (and others) as needed. To view
Postfix configuration values, see postconf(1).

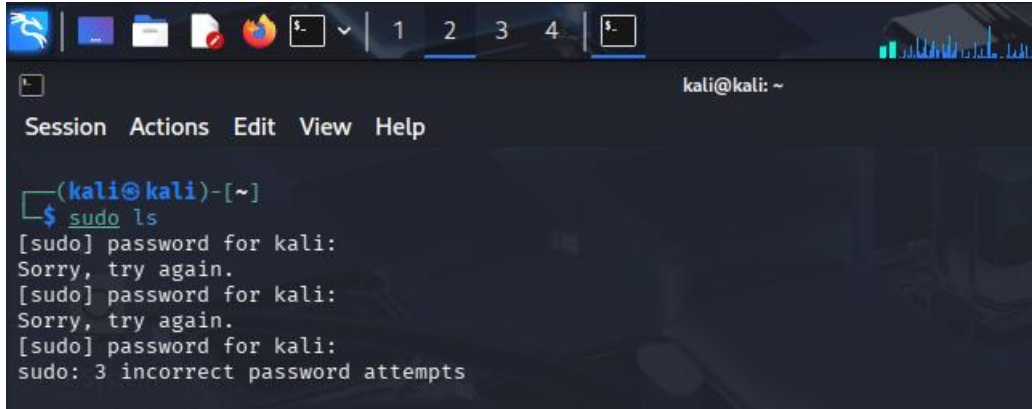
After modifying main.cf, be sure to run 'systemctl reload postfix'.

Processing triggers for doc-base (0.11.2) ...
Processing 3 removed doc-base files...
Processing triggers for libc-bin (2.41-12) ...
Processing triggers for rsyslog (8.2512.0-2) ...
Processing triggers for man-db (2.13.1-1) ...
Processing triggers for kali-menu (2025.4.3) ...
Processing triggers for postfix (3.10.6-1) ...
Restarting postfix
postfix.service is a disabled or a static unit not running, not starting it.
```

Relancer le script :

```
(root@kali)-[/home/kali/Desktop]
# sudo ./script_de_surveillance_sudo.sh
Surveillance des tentatives sudo échouées ...
```

Insérer les faux mots de passe depuis le terminal 2 :



```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ sudo ls
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
sudo: 3 incorrect password attempts
```

Aucun message d'alerte reçu dans le terminal 1 :

```
(root@kali)-[/home/kali/Desktop]
# sudo ./script_de_surveillance_sudo.sh
Surveillance des tentatives sudo échouées ...
^C

(kali@kali)-[/home/kali/Desktop]
# sudo mail
No mail for root
```

Afficher les sorties des logs avec cette commande :

sudo grep -r "sudo" /var/log/ 2>/dev/null | tail -n 20

```

(root@kali)~[/home/kali/Desktop]
# sudo grep -r "sudo" /var/log/ 2>/dev/null | tail -n 20
/var/log/auth.log:2026-01-07T18:47:57.076265-05:00 kali sudo:    root : TTY=pts/1 ; PWD=/home/kali/Desktop ; USER=
root ; COMMAND=./script_de_surveillance_sudo.sh
/var/log/auth.log:2026-01-07T18:47:57.076412-05:00 kali sudo: pam_unix(sudo:session): session opened for user root(
uid=0) by kali(uid=0)
/var/log/auth.log:2026-01-07T18:48:05.717932-05:00 kali sudo: pam_unix(sudo:auth): conversation failed
/var/log/auth.log:2026-01-07T18:48:05.720050-05:00 kali sudo: pam_unix(sudo:auth): auth could not identify password
for [kali]
/var/log/auth.log:2026-01-07T18:48:05.723909-05:00 kali sudo:    kali : 2 incorrect password attempts ; TTY=pts/3
; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/ls
/var/log/auth.log:2026-01-07T18:48:10.151412-05:00 kali sudo: pam_unix(sudo:auth): authentication failure; logname=
kali uid=1000 euid=0 tty=/dev/pts/3 ruser=kali rhost= user=kali
/var/log/auth.log:2026-01-07T18:49:10.521291-05:00 kali sudo:    kali : 3 incorrect password attempts ; TTY=pts/3
; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/ls
/var/log/auth.log:2026-01-07T18:49:55.591358-05:00 kali sudo: pam_unix(sudo:auth): authentication failure; logname=
kali uid=1000 euid=0 tty=/dev/pts/3 ruser=kali rhost= user=kali
/var/log/auth.log:2026-01-07T18:50:18.974494-05:00 kali sudo:    kali : 3 incorrect password attempts ; TTY=pts/3
; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/ls
/var/log/auth.log:2026-01-07T18:57:02.180641-05:00 kali sudo: pam_unix(sudo:session): session closed for user root
/var/log/auth.log:2026-01-07T18:57:07.048959-05:00 kali sudo:    root : TTY=pts/1 ; PWD=/home/kali/Desktop ; USER=
root ; COMMAND=/usr/bin/mail
/var/log/auth.log:2026-01-07T18:57:07.049161-05:00 kali sudo: pam_unix(sudo:session): session opened for user root(
uid=0) by kali(uid=0)
/var/log/auth.log:2026-01-07T18:57:07.070150-05:00 kali sudo: pam_unix(sudo:session): session closed for user root
/var/log/auth.log:2026-01-07T18:57:43.131718-05:00 kali sudo:    root : TTY=pts/1 ; PWD=/home/kali/Desktop ; USER=
root ; COMMAND=./script_de_surveillance_sudo.sh
/var/log/auth.log:2026-01-07T18:57:43.131956-05:00 kali sudo: pam_unix(sudo:session): session opened for user root(
uid=0) by kali(uid=0)
/var/log/auth.log:2026-01-07T18:59:43.262756-05:00 kali sudo: pam_unix(sudo:auth): authentication failure; logname=
kali uid=1000 euid=0 tty=/dev/pts/3 ruser=kali rhost= user=kali
/var/log/auth.log:2026-01-07T19:00:42.613248-05:00 kali sudo:    kali : 3 incorrect password attempts ; TTY=pts/3
; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/ls
/var/log/auth.log:2026-01-07T19:08:08.002627-05:00 kali sudo: pam_unix(sudo:session): session closed for user root
/var/log/auth.log:2026-01-07T19:08:11.097786-05:00 kali sudo:    root : TTY=pts/1 ; PWD=/home/kali/Desktop ; USER=
root ; COMMAND=/usr/bin/grep -r sudo /var/log/
/var/log/auth.log:2026-01-07T19:08:11.097929-05:00 kali sudo: pam_unix(sudo:session): session opened for user root(
uid=0) by kali(uid=0)

```

Le problème est que le système ne lit pas les logs dans le fichier /var/log/auth.log mais depuis le journal du système.

Ensuite, afficher les derniers logs dans le journal avec cette commande :

sudo journalctl -f | grep sudo

```

(root@kali)~[/home/kali/Desktop]
# sudo journalctl -f | grep sudo
Jan 07 19:12:58 kali sudo[26274]:    root : TTY=pts/1 ; PWD=/home/kali/Desktop ; USER=root ; COMMAND=/usr/bin/jour
nalctl -f
Jan 07 19:12:58 kali sudo[26274]: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=0)
^[A^[[A^C

```

Remplacer le fichier /var/log/auth.log dans le script par journalctl.

```
(kali㉿kali)-[~]  
$ sudo ls  
[sudo] password for kali:  
sorry, try again.  
[sudo] password for kali:  
sorry, try again.  
[sudo] password for kali:  
sudo: 3 incorrect password attempts
```

```
(root㉿kali)-[/home/kali/Desktop]  
# sudo ./script_de_surveillance_sudo.sh  
Surveillance en temps réel des tentatives sudo échouées via journalctl...  
^[[A^[[B^[[B^C
```

Cela ne marche toujours pas.

```
(root㉿kali)-[/home/kali/Desktop]  
# sudo mail  
No mail for root
```

Plusieurs tentatives de debug furent appliquées mais sans succès :

```
kali-linux-2025.4-virtualbox-amd64 - Projet d'eddy VM 1 Linux vlnres (Snapshot 1 Vulnerabilites precedentes +...
File Machine View Input Devices Help

root@kali: /home/kali/Desktop

Session Actions Edit View Help

root ; COMMAND=/usr/bin/grep -r sudo /var/log/
/var/log/auth.log:2026-01-07T19:08:11.097929-05:00 kali sudo: pam_unix(sudo:session): session opened for user root(
uid=0) by kali(uid=0)

(root@kali)-[/home/kali/Desktop]
# sudo journalctl -f | grep sudo
Jan 07 19:12:58 kali sudo[26274]: root : TTY=pts/1 ; PWD=/home/kali/Desktop ; USER=root ; COMMAND=/usr/bin/jour
nalctl -f
Jan 07 19:12:58 kali sudo[26274]: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=0)
^[A^[[A^C

(root@kali)-[/home/kali/Desktop]
# nano script_de_surveillance_sudo.sh

(root@kali)-[/home/kali/Desktop]
# chmod +x script_de_surveillance_sudo.sh

(root@kali)-[/home/kali/Desktop]
# sudo ./script_de_surveillance_sudo.sh
Surveillance en temps réel des tentatives sudo échouées via journalctl ...
^[A^[[B^[[B^C

(root@kali)-[/home/kali/Desktop]
# sudo mail
No mail for root

(root@kali)-[/home/kali/Desktop]
# nano script_de_surveillance_sudo.sh

(root@kali)-[/home/kali/Desktop]
# sudo ./script_de_surveillance_sudo.sh
Surveillance en temps réel des tentatives sudo échouées via journalctl ...
journalctl: option requires an argument -- 'o'
Surveillance des tentatives sudo échouées ...
./script_de_surveillance_sudo.sh: line 21: unexpected EOF while looking for matching ```

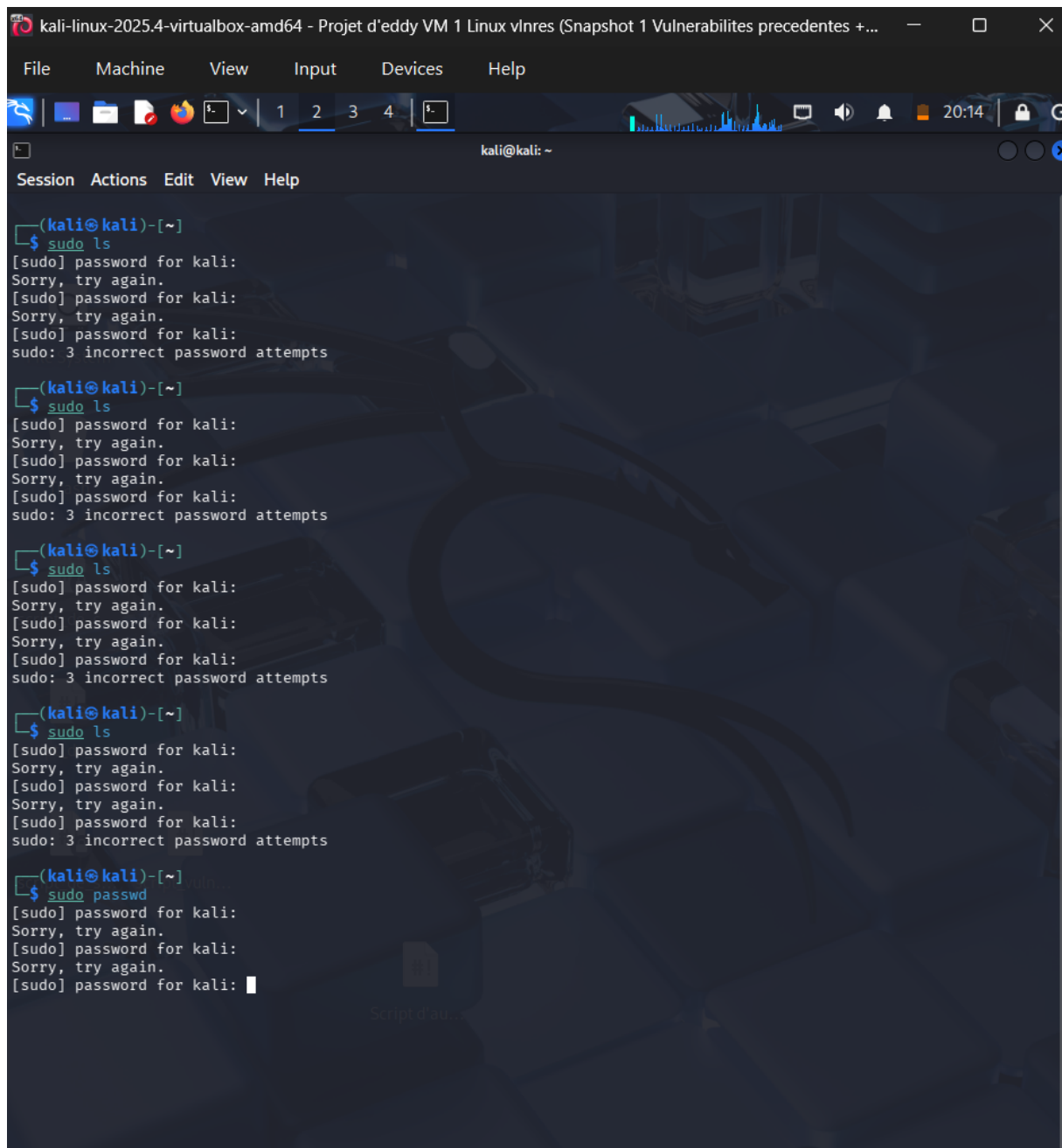
(root@kali)-[/home/kali/Desktop]
# nano script_de_surveillance_sudo.sh

(root@kali)-[/home/kali/Desktop]
# sudo ./script_de_surveillance_sudo.sh
Surveillance en temps réel des tentatives sudo échouées via journalctl ...
^C

(root@kali)-[/home/kali/Desktop]
# nano script_de_surveillance_sudo.sh

(root@kali)-[/home/kali/Desktop]
# nano script_de_surveillance_sudo.sh

(root@kali)-[/home/kali/Desktop]
# sudo ./script_de_surveillance_sudo.sh
Surveillance en temps réel des tentatives sudo échouées via journalctl ...
```


A screenshot of a Kali Linux terminal window. The window title is "kali-linux-2025.4-virtualbox-amd64 - Projet d'eddy VM 1 Linux vlnres (Snapshot 1 Vulnerabilites precedentes +...". The terminal shows a series of failed sudo attempts. The user enters "sudo ls" and is prompted for a password. After three incorrect attempts, the terminal displays "sudo: 3 incorrect password attempts". This sequence is repeated four times. The terminal background has a dark theme with a faint, stylized image of a dragon or mythical creature. The terminal prompt is "(kali@kali)-[~]". The window includes a menu bar with "File", "Machine", "View", "Input", "Devices", and "Help". The status bar at the bottom shows "kali@kali: ~" and a system tray with icons for network, volume, and time (20:14).

Une surveillance a été réalisée sur la vulnérabilité liée aux permissions de fichiers (/etc/shadow). D'autres tentatives de journalisation (telle que la modification cron qui consistait à vérifier si le script de surveillance de la tâche cron détecte la modification de son script même lors de son exécution ou il doit d'abord être relancer. Ces différents audits ont permis d'approfondir le fonctionnement des services de logs sous Linux. De plus, elles ont permis de mieux comprendre la détection d'événements de sécurité et la complexité des outils système comme rsyslog et journalctl.

8- ANALYSE DES RÉSULTATS :

I-Préparation et vulnérabilités introduites

Deux vulnérabilités principales ont été implémentées sur la VM Linux :

Vulnérabilité 1 : Permissions incorrectes sur le fichier `/etc/shadow`.

Le fichier contenant **les hashes de mots de passe** a été rendu lisible par tous les utilisateurs (**chmod 644**), rendant possible la récupération des hashes et leur exploitation.

Vulnérabilité 2 : Tâche cron mal sécurisée.

Un script exécutable par root avec des **permissions 777** a été ajouté dans `/usr/local/bin` puis **planifié par cron**. Ce défaut permet à **tout utilisateur de modifier le script exécuté par root et d'obtenir une élévation de privilèges**.

Ces vulnérabilités reproduisent des cas concrets d'erreurs de configuration souvent rencontrées en administration système. Leur utilisation dans ce projet nous a permis de voir la manière dont les attaquants utilisent des failles avantageuses et comment les contrer.

II-Audit et détection des vulnérabilités

Deux scripts Bash ont été développés pour auditer la machine :

Script d'audit des permissions (Linux) : vérifie les permissions du fichier `/etc/shadow` et signale toute ouverture excessive (≥ 644).

Résultat : le script a bien identifié la permission incorrecte sur `/etc/shadow` avant la correction et a confirmé le retour à une configuration sécurisée (**640**) après modification.

Audit cron vulnérable : liste les tâches cron exécutées par root et détecte les scripts ayant des permissions trop larges (≥ 777).

Résultat : le script a repéré le fichier `/usr/local/bin/script_vuln.sh` exécuté par **cron** et affiché comme vulnérable, validant ainsi la détection.

Ces audits ont montré l'efficacité d'un diagnostic automatisé pour repérer rapidement des failles graves et le fonctionnement des automatisations des scripts.

III-Surveillance et alertes

Deux approches de surveillance ont été mises en place :

Surveillance du fichier /etc/shadow :

Surveillance en temps réel de **/var/log/auth.log** pour repérer toute tentative d'accès ou d'exploitation du fichier sensible.

Lors de tests avec des utilisateurs **non root**, le script a détecté les erreurs "**Permission denied**" et enregistré les alertes dans un **fichier journal local**.

Résultat : détection correcte sur les accès refusés, confirmant que la vulnérabilité était exploitée ou protégée selon la configuration.

Surveillance de la tâche cron mal sécurisée (optionnelle) :

Un script de suivi a été réalisé pour comparer régulièrement l'empreinte **SHA256** du fichier vulnérable avec la précédente.

Bien que le mail d'alerte n'ait pas été pleinement fonctionnel à cause du **MTA inactif sur Kali Linux**, les **alertes locales** ont confirmé la **détection des modifications**.

Vue globale :

L'ensemble des expérimentations réalisées lors de ce projet démontre une progression logique dans la mise en œuvre et la compréhension du **cycle complet de gestion des vulnérabilités**. Chaque étape de la conception à la surveillance a permis d'évaluer concrètement les conséquences de mauvaises configurations et l'efficacité des contre-mesures possibles.

D'une part, les **scripts d'audit** furent efficaces dans la **détection proactive des failles**. Grâce à un ensemble de commandes Bash, il a été **possible d'automatiser des vérifications essentielles** liées aux **permissions de fichiers, aux privilèges d'utilisateurs** et à la **configuration des tâches planifiées**. Ces scripts montrent que, même sans outils spécialisés, un administrateur système peut identifier des menaces graves avec une approche méthodique basée sur **les logs** et **les droits d'accès**. Leur exécution régulière contribuerait à maintenir une politique de sécurité continue.

D'autre part, la **mise en place de la surveillance et des alertes** a mis en évidence les limites d'un système lorsqu'il n'est pas correctement supervisé. Les tests sur **/etc/shadow** et sur le **script cron vulnérable** ont permis d'observer en direct la sensibilité de ces fichiers critiques. Le fait de déclencher des alertes au moment précis d'une tentative d'accès ou d'une modification montre concrètement comment la journalisation peut devenir un outil défensif efficace. En revanche, l'expérimentation a aussi dévoilé certaines contraintes : la **dépendance aux services de logs (rsyslog, journalctl)** et à un **agent de messagerie** actif pour garantir la réactivité du système.

Sur le plan pédagogique, ces essais illustrent parfaitement la complémentarité entre **audit statique** (détection d'erreurs de configuration existantes) et **surveillance dynamique** (réaction en temps réel aux événements). Ces deux approches combinées renforcent la posture de sécurité d'un système en donnant à l'administrateur une visibilité à la fois préventive et réactive sur les risques.

Enfin, la démarche a mis en lumière l'importance de la **traçabilité** : les journaux constituent la mémoire du système. Une bonne gestion des logs (rotation, filtrage, analyse ciblée) facilite les investigations post-incident et soutient la conformité avec les politiques de sécurité.

En conclusion, cette phase d'analyse prouve que la compréhension détaillée du fonctionnement des permissions, de cron, et des mécanismes de logging est fondamentale pour anticiper et limiter les risques d'exploitation. Ces exercices pratiques nous ont préparés à des environnements réels où la rapidité de détection d'une anomalie conditionne directement la sécurité globale de l'infrastructure.

9- RECOMMANDATIONS DE SÉCURITÉ

À la suite de l'audit et de la surveillance des vulnérabilités introduites, plusieurs actions correctives et préventives ont été identifiées pour

renforcer la sécurité du système d'exploitation. Ces recommandations s'appuient sur les observations tirées des tests et reflètent les bonnes pratiques d'administration sécurisée.

1- Protection des fichiers sensibles

Limiter les permissions des fichiers critiques :

Les fichiers tels que **/etc/shadow**, **/etc/passwd**, **/etc/sudoers** doivent conserver des permissions strictes (**par exemple, 640 pour /etc/shadow**). Cela empêche tout utilisateur non privilégié d'accéder aux **hashs de mots de passe** et **réduit considérablement le risque de compromission**.

Surveiller les modifications non autorisées :

Mettre en place des mécanismes automatisés d'audit ou d'intégrité (ex. : Tripwire) permettant de détecter toute modification sur ces fichiers.

2- Sécurisation des tâches planifiées (cron)

Restreindre les permissions des scripts exécutés en tâche cron :

Aucun script exécuté par cron ne doit être modifiable par tous (**chmod 777** proscrit). Les scripts appartenant à root doivent être configurés avec **chmod 700 ou 750**.

Contrôler le contenu de **/etc/crontab** et **/etc/cron.d** régulièrement afin d'éviter l'ajout de processus non autorisés.

Centraliser les logs cron : conserver une trace des exécutions planifiées, et surveiller les signatures (**sha256sum**) des scripts critiques.

3- Renforcement des comptes et mots de passe

Implémenter des politiques de mot de passe robuste :

Utiliser **pam_pwquality** pour imposer une longueur minimale (≥ 10 caractères) avec majuscules, minuscules, chiffres et symboles.

Supprimer ou désactiver les comptes inutilisés :

Chaque compte non utilisé représente une porte potentielle pour une intrusion.

Interdire les droits sudo inutiles :

Seuls les utilisateurs autorisés doivent figurer dans le fichier **/etc/sudoers**, avec des privilèges précisément limités.

4- Gestion et analyse des logs

Activer et configurer les services de logging (**rsyslog**, **systemd-journald**) pour assurer la traçabilité complète des événements système.

Mettre en place la rotation automatique des logs (**logrotate**) afin d'éviter toute **saturation de disque**.

Automatiser l'analyse de logs : intégrer des outils comme **fail2ban** ou **logwatch** pour repérer les tentatives récurrentes d'accès non autorisées.

5-Surveillance et alertes

Automatiser la surveillance au démarrage :

Configurer les scripts de surveillance en tant que services systemd pour assurer leur exécution à chaque redémarrage.

Centraliser les alertes via un système de messagerie interne ou un SIEM (ex. : Wazuh) pour faciliter la corrélation d'événements.

6 - Pratiques générales de sécurité (Hardening)

Mettre à jour régulièrement le système et les paquets (apt update && apt upgrade).

Les correctifs comblent la majorité des vulnérabilités exploitables.

Restreindre les services actifs : désactiver ou désinstaller tout service non nécessaire (FTP, Telnet, etc.).

Configurer un pare-feu (ufw ou iptables) pour limiter les connexions réseau aux services essentiels.

Sauvegarder régulièrement les données et configurations critiques.

La sauvegarde est la dernière défense contre la corruption et les ransomwares.

Ces actions correctives constituent une base solide pour durcir la configuration d'un environnement Linux et réduire considérablement la surface d'attaque. En complément, l'implémentation d'outils d'analyse de logs et de supervision continues renforcerait durablement la détection et la prévention d'incidents de sécurité.

10 – DIFFICULTÉS RENCONTRÉES ET LEÇONS APPRISES

Ce projet m'a permis de développer de nouvelles compétences techniques et une meilleure compréhension du fonctionnement interne des systèmes Linux, tout en rencontrant plusieurs défis techniques significatifs.

Au fil du projet, j'ai acquis une solide expérience dans la gestion et l'analyse des vulnérabilités système :

Création et automatisation de scripts Bash pour auditer ou surveiller des environnements Linux ;

Exploitation contrôlée de vulnérabilités afin d'en observer les impacts réels ;

Gestion des permissions et compréhension approfondie des principes de privilèges sous Linux ;

Pratique de l'élévation et la restriction des droits d'accès grâce à sudo et aux modifications ciblées de fichiers systèmes ;

Capacité à modifier un script actif sans en rompre l'exécution ;

Lecture, filtrage et interprétation des fichiers de logs système ;

Détection et suivi des tentatives d'intrusion ou d'accès non autorisé grâce aux journaux ;

Mise en place d'un service d'envoi d'alertes par mail (mailutils) ;

Et surtout, un développement de ma résilience face aux échecs techniques et à la complexité des configurations.

Ces apprentissages m'ont permis d'améliorer ma rigueur, ma persévérance et ma capacité à résoudre des problèmes en autonomie.

Difficultés rencontrées

Plusieurs obstacles techniques ont jalonné la progression du projet :

La **configuration de mailutils avec les scripts de surveillance**, notamment la livraison des mails locaux qui nécessitait un MTA actif pour fonctionner ;

Des **défis de permissions** lors de la modification de certains sous-dossiers cachés, ce qui a entraîné des difficultés d'accès ou de sauvegarde de scripts ;

La nécessité de maîtriser plusieurs services simultanément (**cron, rsyslog, journalctl, pam_pwquality**), qui ont demandé beaucoup d'expérimentation et de tests pour être compris en profondeur.

Malgré ces difficultés, elles ont constitué de belles opportunités d'apprentissage pratique et de renforcement des connaissances en sécurité informatique. L'expérience acquise sur la configuration, la détection d'intrusions et la sécurisation des systèmes s'est révélée extrêmement enrichissante.

12 – REMÉDIATION DES VULNÉRABILITÉS

1^{ère} Vulnérabilité : Permissions incorrectes sur /etc/shadow (Linux)

Le fichier /etc/shadow était accessible à tous (chmod 644), ce qui exposait les hashes de mots de passe à des utilisateurs non privilégiés.

ls -l /etc/shadow pour afficher les permissions du fichier

```
(root@kali)-[/home/kali]
# ls -l /etc/shadow
-rw-r----- 1 root shadow 1496 Jan  7 18:46 /etc/shadow
```

Afin de restreindre l'accès du fichier au root et au groupe et d'empêcher toute fuite de hashes de mots de passe :

Sudo chmod 600 /etc/shadow

```
(root@kali)-[/home/kali]
# sudo chmod 600 /etc/shadow
```

Restrictions appliquées avec succès :

```
(root@kali)-[/home/kali]
# ls -l /etc/shadow
-rw----- 1 root shadow 1496 Jan  7 18:46 /etc/shadow
```

Seul le root et le son groupe peuvent lire et accéder au fichier.

```
(root@kali)-[/home/kali]
# cat /etc/shadow
*:20425:0:99999:7:::
*:20425:0:99999:7:::
20425:0:99999:7:::
20425:0:99999:7:::
20425:0:99999:7:::
*:20425:0:99999:7:::
20425:0:99999:7:::
20425:0:99999:7:::
20425:0:99999:7:::
20425:0:99999:7:::
*:20425:0:99999:7:::
20425:0:99999:7:::
20425:0:99999:7:::
*:20425:0:99999:7:::
20425:0:99999:7:::
20425:0:99999:7:::
20425:0:99999:7:::
20425:0:99999:7:::
*:20425:::1:
!20425:::
timesync:!*:20425:::1:
us:!*:20425:::
425:::
an:!*:20425:::
!*:20425:::
```

Personne d'autre ne peut lire ni accéder au fichier :

```
kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ cat /etc/shadow
cat: /etc/shadow: Permission denied
(kali@kali)-[~]
$
```

2^{ème} Vulnérabilité : Script cron mal sécurisé (Linux)

```
root@kali: /home/kali
Session Actions Edit View Help
(root@kali)~/home/kali
# ls -l /usr/local/bin/script_vuln.sh
-rw-r--r-- 1 root root 0 Jan 7 09:29 /usr/local/bin/script_vuln.sh
```

Le fichier **/usr/local/bin/script_vuln.sh** possédait des permissions **777** et était exécuté par cron avec le droit root.

En premier lieu, restreindre les permissions du script :

sudo chmod 700 /usr/local/bin/script_vuln.sh

Vérifier le propriétaire du fichier :

sudo chown root: root /usr/local/bin/script_vuln.sh

```
(root@kali)~/home/kali
# sudo chown root:root /usr/local/bin/script_vuln.sh
(root@kali)~kali
#
```

Vérifier dans **/etc/cron.d** et **/etc/crontab** qu'aucune exécution non souhaitée n'existe.

cat /etc/crontab

```

(root@kali)-[~kali]
# cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6 * * 7 root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6 1 * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#

```

Une vérification manuelle du fichier system-wide /etc/crontab a été effectuée afin d'identifier toute tâche potentiellement dangereuse ou non autorisée. Ce fichier a pour objectif de planifier les exécutions automatiques liées à la maintenance du système (exécution quotidienne, hebdomadaire ou mensuelle de scripts système légitimes).

Aucune ligne dangereuse liée au fichier actuel ou à l'ancien script vulnérable ne s'y trouve. /etc/crontab est propre, aucun script externe ou suspect n'est lancé et n'a donc pas besoin d'être modifié. Il n'y a que la maintenance système standard qui est en cours d'exécution.

Mesure appliquée : aucune modification requise, le fichier /etc/crontab ne présente aucune exécution non souhaitée. Il reste intact et conforme aux bonnes pratiques.

/etc/cron.d :

```
cat /etc/cron.d/*
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/libexec/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
#
# Start john everyday at the same to try to crack the passwords. The
# second line will then later stop the process so that it doesn't
# consume system resources that are needed otherwise. You are
# encouraged to change the times.
#
# Also notice that John is 'nice'd, if you don't like this (you
# believe that your system can run fine with john doing its work)
# just remove the 'nice' call
#
# JOHN_OPTIONS = foo bar (man 5 crontab)
#
#00 1 * * * root [ -x /usr/share/john/cronjob ] && nice /usr/share/john/cronjob start
#00 7 * * * root [ -x /usr/share/john/cronjob ] && /usr/share/john/cronjob stop
# /etc/cron.d/php@PHP_VERSION@: crontab fragment for PHP
# This purges session files in session.save_path older than X,
# where X is defined in seconds as the largest value of
# session.gc_maxlifetime from all your SAPI php.ini files
# or 24 minutes if not defined. The script triggers only
# when session.save_handler=files.
#
# WARNING: The scripts tries hard to honour all relevant
# session PHP options, but if you do something unusual
# you have to disable this script and take care of your
# sessions yourself.
#
# Look for and purge old sessions every 30 minutes
09,39 * * * * root [ -x /usr/lib/php/sessionclean ] && if [ ! -d /run/systemd/system ]; then /usr/lib/php/sessionclean; fi
# The first element of the path is a directory where the debian-sal
# script is located
PATH=/usr/libexec/sysstat:/usr/sbin:/usr/sbin:/usr/bin:/sbin:/bin
#
# Activity reports every 10 minutes everyday
5-55/10 * * * * root command -v debian-sal > /dev/null && debian-sal 1 1
#
# Additional run at 23:59 to rotate the statistics file
59 23 * * * root command -v debian-sal > /dev/null && debian-sal 60 2
```

Le répertoire /etc/cron.d a également été analysé pour y rechercher toute trace d'exécution non légitime. Ce dossier contient généralement des fichiers utilisés par des applications pour exécuter des tâches système planifiées. Après listing et lecture du contenu des différents fichiers (e2scrub_all, john, php, sysstat), aucune commande suspecte ni exécution de script externe n'a été détectée.

Les fichiers présents correspondent à :

e2scrub_all : vérification périodique de l'intégrité des systèmes de fichiers.

john : planification du service John the Ripper (programme d'audit de mots de passe légitime installé manuellement).

php : nettoyage régulier des fichiers de sessions PHP pour éviter leur accumulation.

sysstat : collecte automatique de statistiques système via sar et iostat.

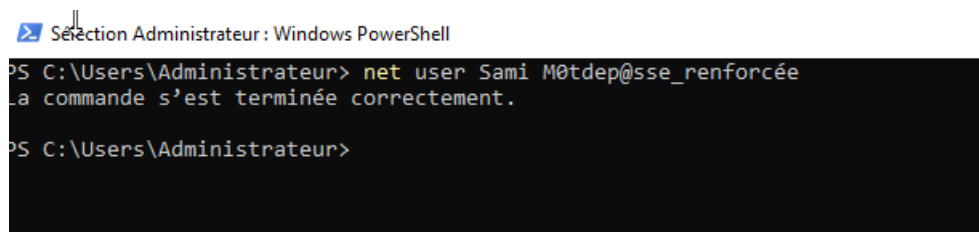
Mesure appliquée : aucune suppression nécessaire. Tous les fichiers contenus dans /etc/cron.d sont liés à des services légitimes du système et ne présentent aucun risque de sécurité. L'environnement cron est donc entièrement assaini.

3^{ème} Vulnérabilité : Compte utilisateur avec mot de passe faible (Windows)

Un utilisateur « Sami » avait été créé avec un mot de passe simple « password123 ». Cette faiblesse pouvait permettre à un attaquant d'obtenir facilement un accès non autorisé via des attaques par dictionnaire ou par force brute.

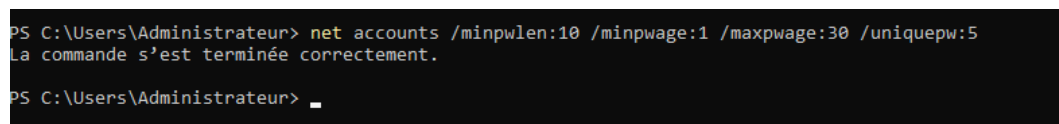
Tout d'abord, modifions le mot de passe de l'utilisateur :

M0tdep@sse_renforcée



```
Sélection Administrateur : Windows PowerShell
PS C:\Users\Administrateur> net user Sami M0tdep@sse_renforcée
La commande s'est terminée correctement.
PS C:\Users\Administrateur>
```

Ensuite, on renforce les politiques de mot de passe locales :



```
PS C:\Users\Administrateur> net accounts /minpwlen:10 /minpwage:1 /maxpwage:30 /uniquepw:5
La commande s'est terminée correctement.
PS C:\Users\Administrateur> _
```

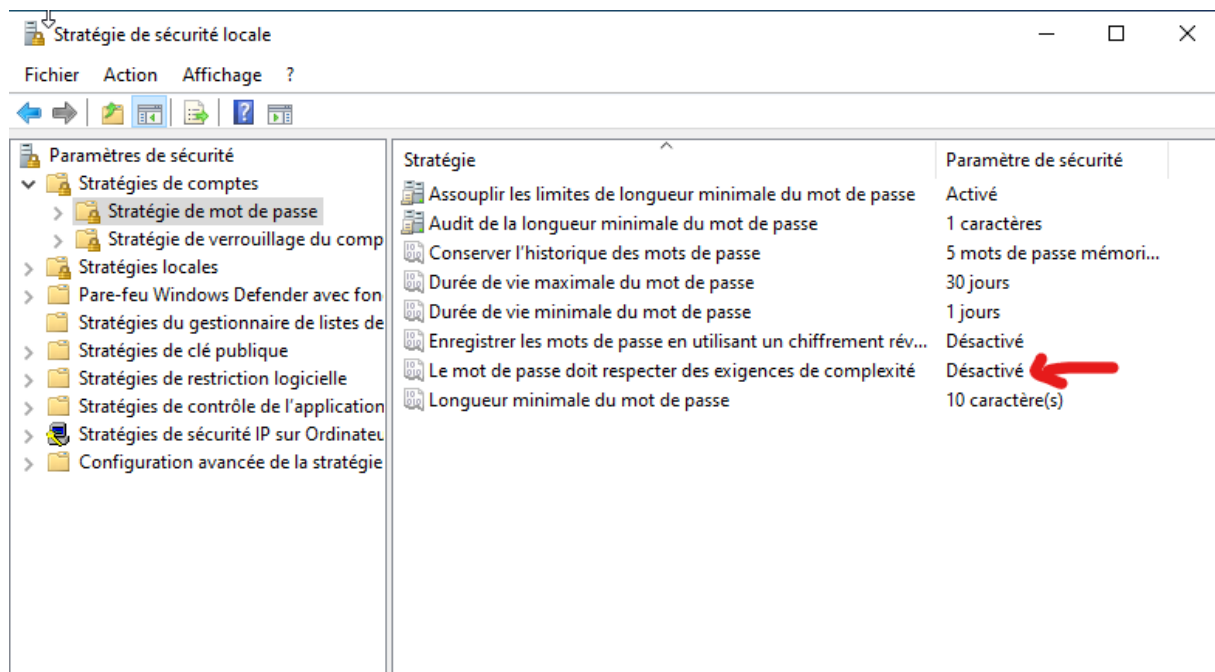
Puis on active la complexité des mots de passe :

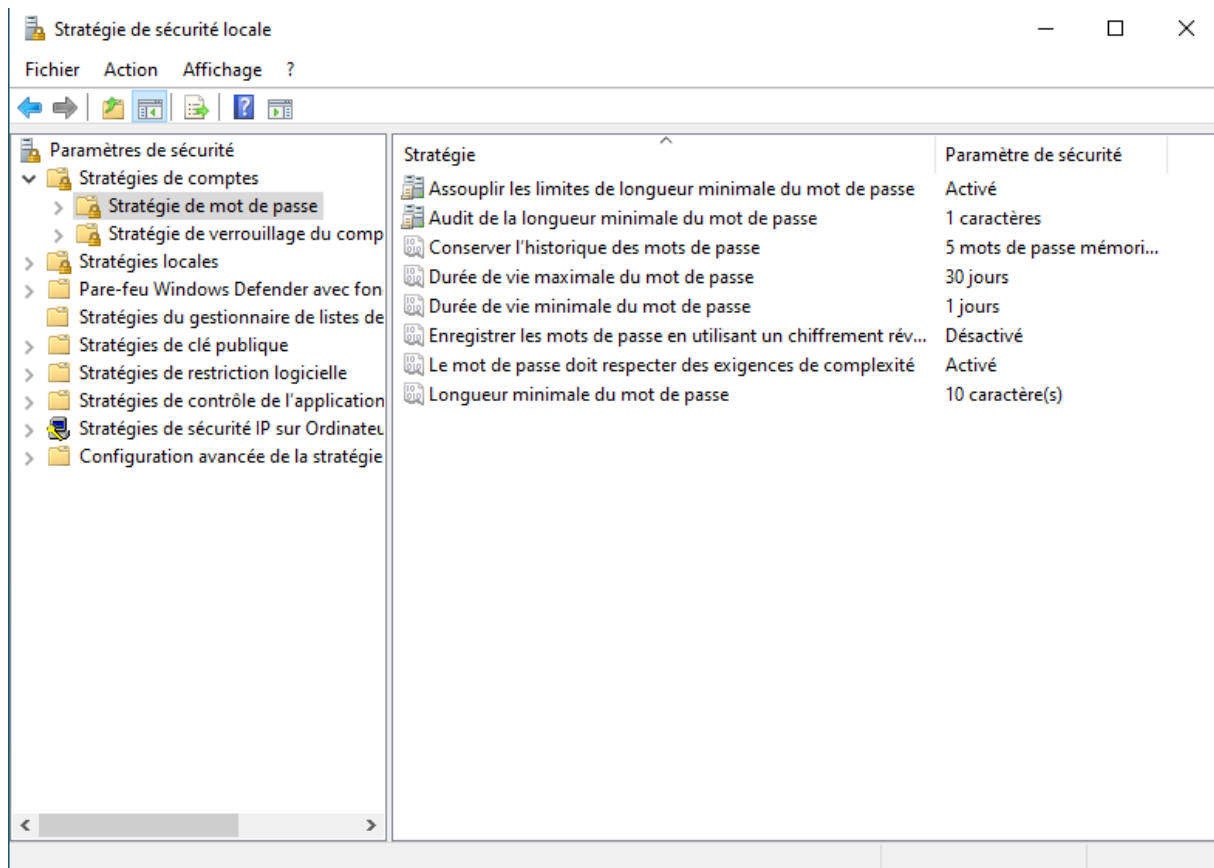
Windows + r :

Entrez : secpol.msc

Allez dans Stratégies de compte - Stratégie de mot de passe –

Activer << Le mot de passe doit respecter des exigences de complexité >>





La commande suivante a permis de lister tous les utilisateurs locaux et d'identifier le compte concerné :

```
net user
```

Résultat : le compte **Sami** a été repéré comme utilisateur local actif.

Renforcement du mot de passe

Un nouveau mot de passe complexe a été défini pour ce compte :

```
net user Sami M0tdepasse_renforcée
```

Ce mot de passe respecte les critères suivants :

Longueur minimale de 10 caractères.

Mélange de majuscules, minuscules, chiffres et symboles.

Absence de mot commun ou de référence directe au nom d'utilisateur.

1 – Application d'une politique de mots de passe sécurisés

Des règles de complexité plus strictes ont été appliquées à tous les comptes locaux via la commande :

`net accounts /minpwlen:10 /minpwage:1 /maxpwage:30 /uniquepw:5`

Effet : les utilisateurs doivent créer un mot de passe d'au moins **10 caractères, changer régulièrement leur mot de passe et ne pas réutiliser les cinq derniers.**

Activation de la complexité dans la stratégie locale

Afin de renforcer la politique de sécurité, la stratégie système suivante a été modifiée :

Ouvrir secpol.msc ;

Naviguer vers Stratégies de compte → Stratégie de mot de passe ;

Activer « **La complexité des mots de passe doit être respectée** ».

Vérification des changements

Après les modifications, l'état du compte a été vérifié :

net user Sami

Résultat : la date de modification du mot de passe a été actualisée et les restrictions de politique se sont appliquées correctement.

```
PS C:\Users\Administrateur> net accounts /minpwlen:10 /minpwage:1 /maxpwage:30 /uniquepw:5
La commande s'est terminée correctement.

PS C:\Users\Administrateur> net user Sami
Nom d'utilisateur                Sami
Nom complet
Commentaire
Commentaires utilisateur
Code du pays ou de la région    000 (Valeur par défaut du système)
Compte : actif                  Oui
Le compte expire                Jamais

Mot de passe : dernier changmt. 14/01/2026 01:07:01
Le mot de passe expire          13/02/2026 01:07:01
Le mot de passe modifiable      15/01/2026 01:07:01
Mot de passe exigé              Oui
L'utilisateur peut changer de mot de passe  Oui

Stations autorisées              Tout
Script d'ouverture de session
Profil d'utilisateur
Répertoire de base
Dernier accès                    Jamais

Heures d'accès autorisé          Tout

Appartient aux groupes locaux    *Utilisateurs
Appartient aux groupes globaux   *Aucun
La commande s'est terminée correctement.

PS C:\Users\Administrateur>
```

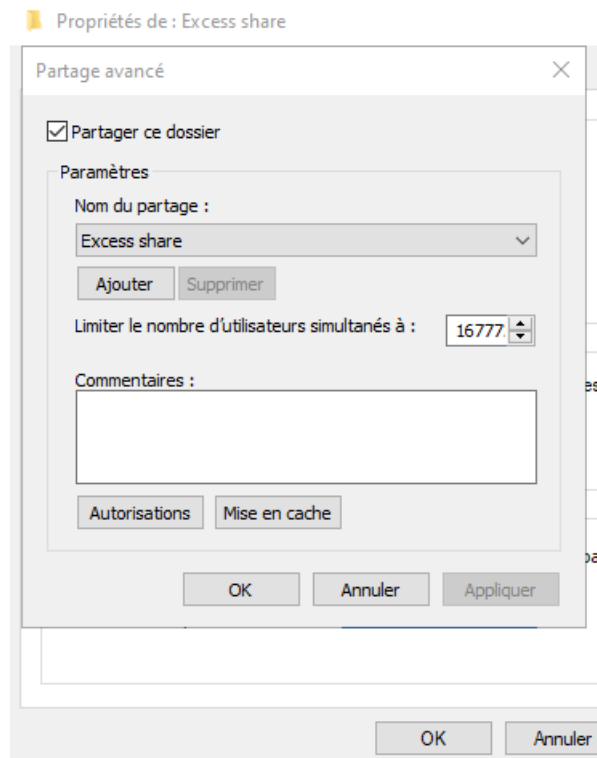
Le compte **Sami** est désormais protégé par un mot de passe complexe conforme aux bonnes pratiques de sécurité. Les politiques de mot de passe locales imposent une longueur minimale, un changement régulier et respectent la complexité exigée. L'ensemble réduit considérablement le risque d'exploitation du compte par une attaque par mot de passe.

4ème Vulnérabilité : Partage réseau trop permissif (Windows)

Le dossier partagé « Excess share » accordait un accès *Contrôle total à Tout le monde*.

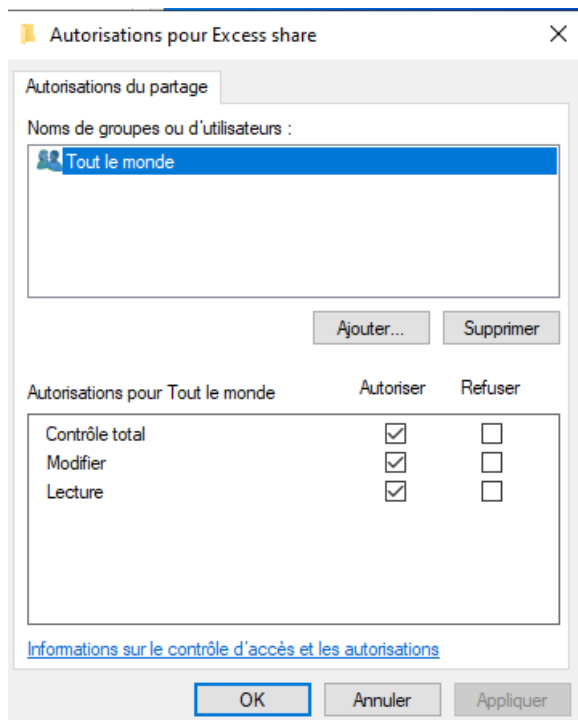
Première étape :

Propriétés du dossier – Onglet Partage – Partage avancé



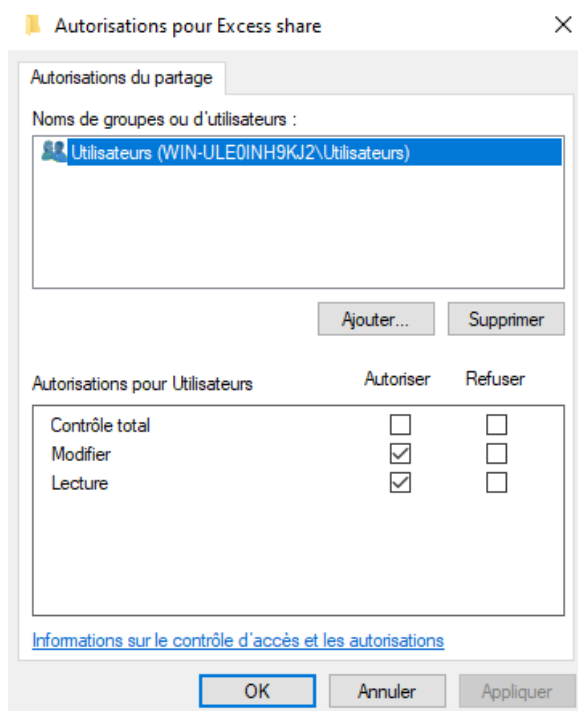
Cliquer sur Autorisations puis :

_Retirer Tout le monde.

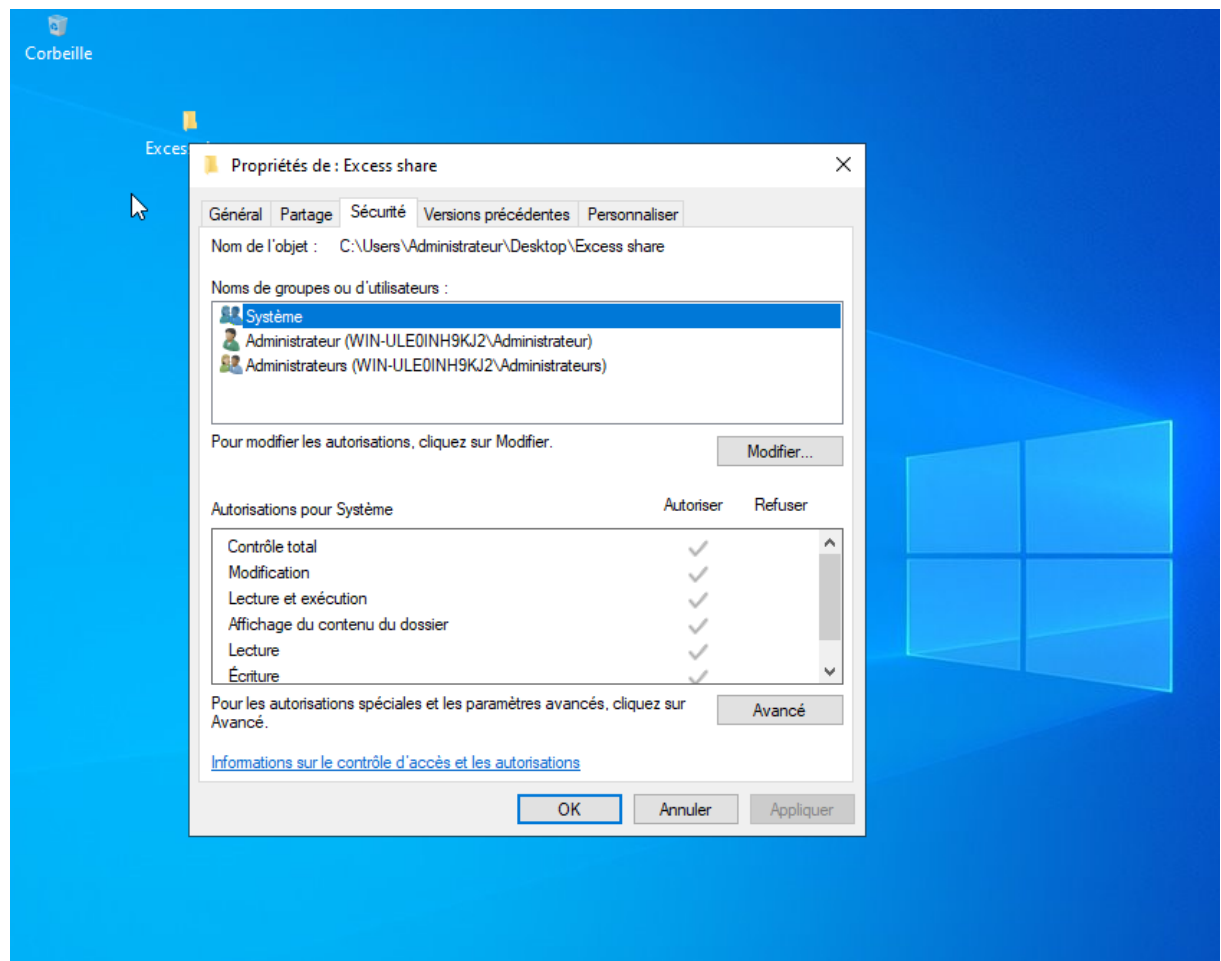


_Ajouter uniquement les utilisateurs ou groupes autorisés.

_Donner seulement les droits nécessaires (lecture ou modification).



Pour finir, vérifier les droits NTFS (New Technology File System) dans l'onglet sécurité pour éviter toute autorisation excessive :



lors de l'audit du système Windows, le dossier partagé « **Excess share** » permettait un **accès en Contrôle total** à “**Tout le monde**”, c'est-à-dire à tous les utilisateurs du réseau, sans distinction d'identité ni de niveau d'autorisation. Cette mauvaise configuration représentait un risque important, car elle offrait la possibilité à quiconque connecté au même réseau d'accéder, de modifier ou de supprimer des fichiers sensibles présents dans le partage. Une telle ouverture compromet directement la **confidentialité et l'intégrité des données**.

Pour corriger cette vulnérabilité, les permissions de partage ont été totalement revues.

Le dossier concerné a été ouvert dans l'Explorateur Windows, puis ses propriétés ont été consultées via l'onglet **Partage -Partage avancé**.

Dans la fenêtre **Autorisations**, l'entrée "**Tout le monde**" a été supprimée afin de restreindre l'accès au répertoire.

Seuls les **utilisateurs ou groupes spécifiques autorisés** (administrateurs ou comptes de confiance) ont été ajoutés, avec seulement les droits nécessaires selon le principe du **moindre privilège** (lecture pour les utilisateurs standards, modification uniquement pour les gestionnaires du dossier).

Enfin, les autorisations NTFS (onglet **Sécurité**) ont été harmonisées afin d'éviter tout conflit entre les permissions de partage et les permissions locales du système de fichiers.

Le dossier « **Excess share** » est désormais protégé : seuls les utilisateurs légitimes peuvent y accéder selon leurs rôles respectifs. Les risques d'accès non autorisés, de suppression ou de modification des données ont été éliminés. Cette remédiation assure un **contrôle strict des ressources partagées** et renforce la sécurité globale du système Windows.

5^{ème} Vulnérabilité : Tâches cron ou scripts exécutables non supervisés (optionnelle)

Absence de mécanisme d'alerte automatique sur les scripts critiques.

Première étape :

Créer un service systemd pour chaque script critique.

```
(root@kali)-[/home/kali/Desktop]
# nano /etc/systemd/system/surveillance.service
```

Deuxième étape : Activer et démarrer le service

Redémarrer la configuration systemd pour prendre en compte le nouveau fichier :

```
(root@kali)-[/home/kali/Desktop]
# sudo systemctl daemon-reload
```

Activer le service pour qu'il se lance au démarrage :

```
(root@kali)-[/home/kali/Desktop]
# sudo systemctl enable surveillance.service
Created symlink '/etc/systemd/system/multi-user.target.wants/surveillance.service' → '/etc/systemd/system/surveillance.service'.
```

Démarrer le script :

```
(root@kali)-[/home/kali/Desktop]
# sudo systemctl start surveillance.service
```

Vérifier son état :

```
(root@kali)-[/home/kali/Desktop]
# sudo systemctl status surveillance.service
• surveillance.service - Service de surveillance des scripts critiques
  Loaded: loaded (/etc/systemd/system/surveillance.service; enabled; preset: disabled)
  Active: failed (Result: exit-code) since Tue 2026-01-13 20:18:35 EST; 1min 9s ago
  Duration: 28ms
  Invocation: e115bb7c16ee40e58562873ab4ee5524
  Process: 6538 ExecStart=/home/kali/scripts/surveillance.sh >> /var/log/surveillance.log 2>61 (code=exited, status=203/EXEC)
  Main PID: 6538 (code=exited, status=203/EXEC)
  Mem peak: 1.7M
  CPU: 10ms

Jan 13 20:18:35 kali systemd[1]: surveillance.service: Scheduled restart job, restart counter is at 5.
Jan 13 20:18:35 kali systemd[1]: surveillance.service: Start request repeated too quickly.
Jan 13 20:18:35 kali systemd[1]: surveillance.service: Failed with result 'exit-code'.
Jan 13 20:18:35 kali systemd[1]: Failed to start surveillance.service - Service de surveillance des scripts critiques.
```

Il ne s'est pas lancé, c'est souvent dû à un mauvais chemin d'accès ou à des permissions trop minimales

Vérifier les permissions du script :

ls -l /etc/systemd/system/surveillance.service

```
(root@kali)-[/home/kali/Desktop]
# ls -l /etc/systemd/system/surveillance.service
-rw-r--r-- 1 root root 239 Jan 13 20:13 /etc/systemd/system/surveillance.service
```

Rendre le script exécutable, lisible et modifiable par le root afin qu'il puisse y avoir le contrôle et appliquer quelque mesure si une situation se présente :

```
(root@kali)-[/home/kali/Desktop]
# ls -l /etc/systemd/system/surveillance.service
-rwxr-xr-x 1 root root 239 Jan 13 20:13 /etc/systemd/system/surveillance.service
```

Le root est le propriétaire du dossier et du fichier : contrôle garanti

```
(root@kali)-[/home/kali/Desktop]
# chown root:root /etc/systemd/system/surveillance.service
```

Excepté cela, la réponse de sortie du système montre que le fichier a un mauvais chemin de sortie. Nous devons aussi créer le fichier log qui gardera les logs :

Tout d'abord, arranger le chemin d'accès du fichier :

```
GNU nano 8.6 /etc/systemd/system/surveil
[Unit]
Description=Service de surveillance des scripts critiques
After=network.target

[Service]
ExecStart=/home/kali/Desktop/surveillance.sh >> /var/log/surveillance.log 2>&1
Restart=always
User=root

[Install]
WantedBy=multi-user.target
```

Création du fichier surveillance.log ainsi que son répertoire de manière manuelle en utilisant la commande **Touch** + Attribution de permissions modéré. Le root détient tous les droits.

```
(root@kali)-[/home/kali/Desktop]
# sudo touch /var/log/surveillance.log

(root@kali)-[/home/kali/Desktop]
# sudo chmod 644 /var/log/surveillance.log
```

Vérifier son emplacement et s'assurer qu'il est sur le bureau avec cette commande :

sudo find /home/kali -name surveillance.sh 2>/dev/null

```
(root@kali)-[/home/kali/Desktop]
# sudo find /home/kali -name surveillance.sh 2>/dev/null
```

Si rien ne s'affiche, c'est que le fichier n'a jamais été créé.

Créons-le sur le Bureau avec un contenu de test depuis la cli :

nano /home/kali/Desktop/surveillance.sh

Contenu de test :

Une ligne sera écrite dans le fichier log toutes les minutes.

Rendre exécutable le fichier et l'attribuer au root puis démarrer a nouveau la configuration système, relancer le script puis vérifier son état.

État du script :

```
(root@kali)-[/home/kali/Desktop]
# sudo systemctl status surveillance.service
● surveillance.service - Service de surveillance des scripts critiques
   Loaded: loaded (/etc/systemd/system/surveillance.service; enabled; preset: disabled)
   Active: active (running) since Tue 2026-01-13 21:14:03 EST; 22s ago
  Invocation: e7943de33dce48e9aa2eb71ec9c90bfc
    Main PID: 33797 (surveillance.sh)
      Tasks: 2 (limit: 4339)
     Memory: 608K (peak: 1.6M)
        CPU: 15ms
    CGroup: /system.slice/surveillance.service
            └─33797 /bin/bash /home/kali/Desktop/surveillance.sh ">" /var/log/surveillance.log "2>61"
              └─33800 sleep 60

Jan 13 21:14:03 kali systemd[1]: Started surveillance.service - Service de surveillance des scripts critiques.
```

Commande insérée dans le script continue de tourner en parallèle :

```
(root@kali)-[/home/kali/Desktop]
# sudo tail -f /var/log/surveillance.log
[INFO] Surveillance active à Tue Jan 13 09:14:03 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:15:03 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:16:03 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:17:05 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:18:05 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:19:05 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:20:05 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:21:05 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:22:05 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:23:05 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:24:05 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:25:05 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:26:05 PM EST 2026
[INFO] Surveillance active à Tue Jan 13 09:27:05 PM EST 2026
```

Sortir du fichier log : **Ctrl C**

Modification du contenu de test :

Un script avancé de surveillance a été implémenté afin de solidifier la surveillance et avoir une meilleure traçabilité

Rendre exécutable :

```
(root@kali)-[/home/kali/Desktop]
# chmod +x /home/kali/Desktop/surveillance.sh
```

Relancer la surveillance et vérifier son état :

```
(root@kali)-[/home/kali/Desktop]
# sudo systemctl restart surveillance.service

(root@kali)-[/home/kali/Desktop]
# sudo systemctl status surveillance.service
● surveillance.service - Service de surveillance des scripts critiques
   Loaded: loaded (/etc/systemd/system/surveillance.service; enabled; preset: disabled)
   Active: active (running) since Tue 2026-01-13 21:34:34 EST; 12s ago
  Invocation: 58f6aa4574b14b95aea0206b5ff439cb
    Main PID: 43701 (surveillance.sh)
      Tasks: 2 (limit: 4339)
     Memory: 4.8M (peak: 6.3M)
        CPU: 45ms
      CGroup: /system.slice/surveillance.service
              └─43701 /bin/bash /home/kali/Desktop/surveillance.sh ">>" /var/log/surveillance.log "2>&1"
                 └─43713 sleep 60

Jan 13 21:34:34 kali systemd[1]: Started surveillance.service - Service de surveillance des scripts critiques.
```

Afficher dernières lignes du journal :

sudo tail -f /var/log/surveillance.log

Tenter un accès sudo sur le fichier surveillance depuis un autre terminal :

```
(kali@kali)-[~]
$ sudo su
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
sudo: 3 incorrect password attempts

(kali@kali)-[~]
$ sudo cat surveillance.sh
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali: █
```



```
(root@kali)-[/home/kali/Desktop]
# sudo tail -f /var/log/surveillance.log
[2026-01-13 21:57:39] Surveillance opérationnelle.
[2026-01-13 21:58:39] Surveillance opérationnelle.
[2026-01-13 21:59:39] Surveillance opérationnelle.
[2026-01-13 22:00:39] Surveillance opérationnelle.
[2026-01-13 22:01:39] Surveillance opérationnelle.
[2026-01-13 22:02:39] Surveillance opérationnelle.
[2026-01-13 22:03:39] Surveillance opérationnelle.
[2026-01-13 22:04:39] Surveillance opérationnelle.
[2026-01-13 22:04:48] == Démarrage du service de surveillance avec alertes ==
[2026-01-13 22:04:48] Surveillance opérationnelle.
[2026-01-13 22:05:48] ⚠ Tentative sudo échouée détectée.
[2026-01-13 22:05:48] 📧 Mail d'alerte envoyé à : Tentative sudo échouée détectée sur kali.
[2026-01-13 22:05:48] Surveillance opérationnelle.
```

```
You have new mail.
(root@kali)-[/home/kali/Desktop]
# sudo mail
"/var/mail/root": 9 messages 9 new
>N 1 kali@kali.lan Tue Jan 13 22:41 14/517 *** SECURITY information for kali ***
N 2 kali@kali Tue Jan 13 22:41 16/564 [ALERTE] Tentative sudo échouée
N 3 kali@kali Tue Jan 13 22:41 16/546 [ALERTE] Tentative sudo échouée
N 4 kali@kali Tue Jan 13 22:41 16/564 [ALERTE] Tentative sudo échouée
N 5 kali@kali.lan Tue Jan 13 22:41 14/534 *** SECURITY information for kali ***
N 6 kali@kali Tue Jan 13 22:41 16/563 [ALERTE] Tentative sudo échouée
N 7 kali@kali Tue Jan 13 22:41 16/564 [ALERTE] Tentative sudo échouée
N 8 kali@kali Tue Jan 13 22:41 16/564 [ALERTE] Tentative sudo échouée
N 9 kali@kali.lan Tue Jan 13 22:42 14/533 *** SECURITY information for kali ***
?
```

```
(root@kali)-[/home/kali/Desktop]
# sudo mail
"/var/mail/root": 10 messages 10 unread
>U 1 kali@kali Tue Jan 13 22:41 19/627 [ALERTE] Tentative sudo échouée
U 2 kali@kali Tue Jan 13 22:41 18/565 [ALERTE] Tentative sudo échouée
U 3 kali@kali Tue Jan 13 22:41 18/583 [ALERTE] Tentative sudo échouée
U 4 kali@kali.lan Tue Jan 13 22:41 16/553 *** SECURITY information for kali ***
U 5 kali@kali Tue Jan 13 22:41 18/582 [ALERTE] Tentative sudo échouée
U 6 kali@kali Tue Jan 13 22:41 18/583 [ALERTE] Tentative sudo échouée
U 7 kali@kali Tue Jan 13 22:41 18/583 [ALERTE] Tentative sudo échouée
U 8 kali@kali.lan Tue Jan 13 22:42 16/552 *** SECURITY information for kali ***
U 9 kali@kali Tue Jan 13 22:50 18/583 [ALERTE] Tentative sudo échouée
U 10 kali@kali Tue Jan 13 22:50 18/584 [ALERTE] Tentative sudo échouée
?
Return-Path: <kali@kali>
X-Original-To: root
Delivered-To: root@kali.lan
Received: by kali.lan (Postfix, from userid 1000)
id 80752C011F; Tue, 13 Jan 2026 22:41:56 -0500 (EST)
Subject: [ALERTE] Tentative sudo échouée
To: root@kali.lan
User-Agent: mail (GNU Mailutils 3.20)
Date: Tue, 13 Jan 2026 21:46:40 -0500
Message-Id: <20260114034156.80752C011F@kali.lan>
From: kali@kali
X-IMAPPhase: 1768362701 13
X-UID: 2
Status: 0

Alerte sécurité sur kali

Tentative sudo échouée détectée :
pam_unix(sudo:auth): authentication failure; logname=kali uid=1000 euid=0 tty=/dev/pts/3 ruser=kali rhost= user=kali
?
```

Le système de sécurité a détecté une tentative qui a échoué et l'a enregistré dans les logs et l'a envoyé dans le mail du root. Le script avancé fonctionne

Le système ne possédait aucun mécanisme d'alerte automatique pour informer l'administrateur en cas d'anomalie sur les scripts de surveillance ou sur des services critiques comme *cron* ou *sudo*. En l'absence de supervision, des dysfonctionnements pouvaient passer inaperçus et compromettre la détection des tentatives d'intrusion ou des erreurs système.

Afin de pallier ce manque, un script Bash avancé a été mis en place et exécuté automatiquement par un service systemd. Celui-ci assure la supervision continue du système et consigne toutes les activités importantes dans un fichier de log dédié (/var/log/surveillance.log). Le script vérifie périodiquement plusieurs points clés :

- _l'état de fonctionnement du service cron ;
- _la détection d'échecs d'authentification sudo dans les journaux système ; et l'espace disque disponible.

En complément, une fonctionnalité d'**alerte mail locale** a été intégrée à ce script. Lorsqu'une anomalie est détectée (service arrêté, tentative sudo échouée, disque presque plein), un courrier électronique automatique est envoyé à l'administrateur root. Ces alertes sont doublées d'une entrée dans le log, garantissant une traçabilité complète.

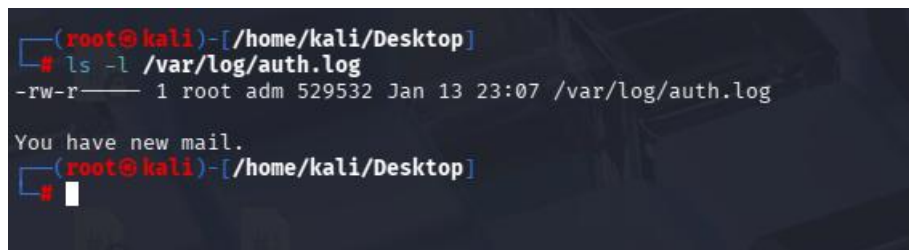
Cette configuration permet d'assurer une **surveillance proactive et autonome du système**. Les incidents critiques sont immédiatement signalés par mail et documentés dans un fichier journal.

L'administrateur est donc informé en temps réel des événements anormaux, ce qui renforce considérablement la réactivité et la fiabilité de la surveillance de la machine.

6^{ème} vulnérabilité : Absence de surveillance des tentatives sudo (Linux)

Première étape : Activer la journalisation via rsyslog ou systemd

Vérifier que le fichier existe :



```
(root@kali)-[/home/kali/Desktop]
# ls -l /var/log/auth.log
-rw-r----- 1 root adm 529532 Jan 13 23:07 /var/log/auth.log

You have new mail.
(root@kali)-[/home/kali/Desktop]
#
```

Il existe.

Nous pouvons visualiser ses dernières lignes :

```
(root@kali) ~ [~/home/kali/Desktop]
# sudo tail -n 20 /var/log/auth.log
2026-01-13T23:05:12.445532-05:00 kali lightdm: gkr-pam: stashed password to try later in open session
2026-01-13T23:05:12.820763-05:00 kali lightdm: pam_unix(lightdm-greeter:session): session closed for user lightdm
2026-01-13T23:05:12.825865-05:00 kali lightdm: pam_unix(lightdm-greeter:session): session closed for user lightdm
2026-01-13T23:05:12.863303-05:00 kali systemd-logind[497]: Removed session c5.
2026-01-13T23:05:15.715270-05:00 kali sudo: pam_unix(sudo:session): session closed for user root
2026-01-13T23:05:23.295918-05:00 kali systemd-logind[497]: Removed session 211.
2026-01-13T23:05:30.842063-05:00 kali sudo: root : TTY=pts/1 ; PWD=/home/kali/Desktop ; USER=root ; COMMAND=/usr/bin/systemctl enable rsyslog
2026-01-13T23:05:30.842226-05:00 kali sudo: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=0)
2026-01-13T23:05:31.213963-05:00 kali sudo: pam_unix(sudo:session): session closed for user root
2026-01-13T23:05:46.821747-05:00 kali sudo: root : TTY=pts/1 ; PWD=/home/kali/Desktop ; USER=root ; COMMAND=/usr/bin/systemctl start rsyslog
2026-01-13T23:05:46.822888-05:00 kali sudo: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=0)
2026-01-13T23:05:46.843603-05:00 kali sudo: pam_unix(sudo:session): session closed for user root
2026-01-13T23:06:01.622524-05:00 kali CRON[94364]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-01-13T23:06:01.653931-05:00 kali CRON[94364]: pam_unix(cron:session): session closed for user root
2026-01-13T23:07:01.667116-05:00 kali CRON[94859]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-01-13T23:07:01.675786-05:00 kali CRON[94859]: pam_unix(cron:session): session closed for user root
2026-01-13T23:08:01.684196-05:00 kali CRON[95386]: pam_unix(cron:session): session opened for user root(uid=0) by root(uid=0)
2026-01-13T23:08:01.694834-05:00 kali CRON[95386]: pam_unix(cron:session): session closed for user root
2026-01-13T23:08:45.694956-05:00 kali sudo: root : TTY=pts/1 ; PWD=/home/kali/Desktop ; USER=root ; COMMAND=/usr/bin/tail -n 20 /var/log/auth.log
2026-01-13T23:08:45.695782-05:00 kali sudo: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid=0)
```

Créer le fichier log depuis le terminal avec la commande touch et appliquer les permissions :

```
_sudo touch /var/log/alerte_sudo.log
```

```
_sudo chmod 644 /var/log/alerte_sudo.log
```

```
(root@kali) ~ [~/home/kali/Desktop]
# sudo touch /var/log/alerte_sudo.log

(root@kali) ~ [~/home/kali/Desktop]
# sudo chmod 644 /var/log/alerte_sudo.log
```

Lancer le script :

```
sudo ./home/kali/scripts/surveillance_sudo.sh
```

Dans un autre terminal, tester le script en le provoquant

Sudo ls :

Entrez un mot de passe erroné.

```
(kali@kali)-[~]
$ sudo ls
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali: 
```

```
(root@kali)-[/home/kali/Desktop]
$ sudo ./surveillance_sudo.sh
== Surveillance des tentatives d'accès root échouées ==
Script démarré à 2026-01-13 23:21:22
[ALERTE 2026-01-13 23:21:44] Tentative sudo échouée détectée : 2026-01-13T23:21:44.148648-05:00 kali sudo: pam_unix(sudo:auth): authentication failure; log
name=kali uid=1000 euid=0 tty=/dev/pts/3 ruser=kali rhost= user=kali
■ Alerte envoyée à root
^C
You have new mail.
```

Le système de surveillance a décelé la tentative d'intrusion.
Enregistrement dans le **journal** et envoi du **mail** au root.

Journal :

```
(root@kali)-[/home/kali/Desktop]
$ cat /var/log/alerte_sudo.log
[ALERTE 2026-01-13 23:21:44] Tentative sudo échouée détectée : 2026-01-13T23:21:44.148648-05:00 kali sudo: pam_unix(sudo:auth): authentication failure; log
name=kali uid=1000 euid=0 tty=/dev/pts/3 ruser=kali rhost= user=kali
```

Mail :

```
(root@kali)-[/home/kali/Desktop]
$ mail
"/var/mail/root": 4 messages 4 new
>N 1 kali@kali Tue Jan 13 23:15 16/572 [ALERTE] Tentative sudo échouée
N 2 kali@kali.lan Tue Jan 13 23:21 14/533 ** SECURITY information for kali **
N 3 root Tue Jan 13 23:21 15/601 [ALERTE] Tentative sudo échouée
N 4 kali@kali Tue Jan 13 23:21 16/564 [ALERTE] Tentative sudo échouée
?
Return-Path: <kali@kali>
X-Original-To: root
Delivered-To: root@kali.lan
Received: by kali.lan (Postfix, from userid 1000)
id 0FBAAC011F; Tue, 13 Jan 2026 23:15:45 -0500 (EST)
Subject: [ALERTE] Tentative sudo échouée
To: root@kali.lan
User-Agent: mail (GNU Mailutils 3.20)
Date: Tue, 13 Jan 2026 23:15:45 -0500
Message-Id: <20260114041545.0FBAAC011F@kali.lan>
From: kali@kali

Alerte sécurité sur kali

Tentative sudo échouée détectée :
root : TTY=pts/2 ; PWD=/home/kali/Desktop ; USER=root ; COMMAND=/usr/bin/grep 'incorrect password attempts' /var/log/auth.log
?
```

Pour que le script de **surveillance_sudo.sh** se lance
automatiquement au démarrage de la machine :

Créer un fichier de service systemd:

S'assurer que le script est exécutable et rendre root propriétaire du fichier :

```
(root@kali)-[/home/kali/Desktop]
# sudo nano /etc/systemd/system/surveillance_sudo.service

(root@kali)-[/home/kali/Desktop]
# sudo chmod +x /home/kali/Desktop/surveillance_sudo.sh

(root@kali)-[/home/kali/Desktop]
# sudo chown root:root /home/kali/Desktop/surveillance_sudo.sh

(root@kali)-[/home/kali/Desktop]
#
```

Activer et démarrer le service :

sudo systemctl daemon-reload

```
(root@kali)-[/home/kali/Desktop]
# sudo systemctl daemon-reload

(root@kali)-[/home/kali/Desktop]
# sudo systemctl enable surveillance_sudo.service
Created symlink '/etc/systemd/system/multi-user.target.wants/surveillance_sudo.service' → '/etc/systemd/system/surveillance_sudo.service'.

(root@kali)-[/home/kali/Desktop]
# sudo systemctl start surveillance_sudo.service
```

Vérifier qu'il tourne correctement :

Sudo systemctl status surveillance_sudo.service

```
(root@kali)-[/home/kali/Desktop]
# sudo systemctl status surveillance_sudo.service
● surveillance_sudo.service - Service de surveillance des tentatives sudo échouées
   Loaded: loaded (/etc/systemd/system/surveillance_sudo.service; enabled; preset: disabled)
   Active: active (running) since Tue 2026-01-13 23:48:41 EST; 59s ago
 Invocation: 583eee2537354f068e0f25bca550b1ea
    Main PID: 117102 (surveillance_su)
      Tasks: 4 (limit: 4339)
     Memory: 2.6M (peak: 3M)
        CPU: 43ms
    CGroup: /system.slice/surveillance_sudo.service
            └─117102 /bin/bash /home/kali/Desktop/surveillance_sudo.sh
               └─117105 sudo tail -Fn0 /var/log/auth.log
                  └─117106 /bin/bash /home/kali/Desktop/surveillance_sudo.sh
                     └─117108 tail -Fn0 /var/log/auth.log

Jan 13 23:48:41 kali systemd[1]: Started surveillance_sudo.service - Service de surveillance des tentatives sudo échouées.
Jan 13 23:48:41 kali surveillance_sudo.sh[117102]: == Surveillance des tentatives d'accès root échouées ==
Jan 13 23:48:41 kali surveillance_sudo.sh[117102]: Script démarré à 2026-01-13 23:48:41
Jan 13 23:48:41 kali sudo[117105]:      root : PWD=/ ; USER=root ; COMMAND=/usr/bin/tail -Fn0 /var/log/auth.log
Jan 13 23:48:41 kali sudo[117105]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=0)
```

Pour voir le fichier rapport, entrez :

sudo tail -n 10 /var/log/alerte_sudo.log

```
(root@kali)-[/home/kali/Desktop]
└─$ sudo tail -n 10 /var/log/alerte_sudo.log
[ALERTE 2026-01-13 23:21:44] Tentative sudo échouée détectée : 2026-01-13T23:21:44.148648-05:00 kali sudo: pam_unix(sudo:auth): authentication failure; log
name=kali uid=1000 euid=0 tty=/dev/pts/3 ruser=kali rhost= user=kali
```

Pour voir les logs du service systemd :

sudo journalctl -u surveillance_sudo.service -f

```
(root@kali)-[/home/kali/Desktop]
└─$ sudo journalctl -u surveillance_sudo.service -f
Jan 13 23:48:41 kali systemd[1]: Started surveillance_sudo.service - Service de surveillance des tentatives sudo échouées.
Jan 13 23:48:41 kali surveillance_sudo.sh[117102]: == Surveillance des tentatives d'accès root échouées ==
Jan 13 23:48:41 kali surveillance_sudo.sh[117102]: Script démarré à 2026-01-13 23:48:41
Jan 13 23:48:41 kali sudo[117105]: root : PWD=/ ; USER=root ; COMMAND=/usr/bin/tail -Fn0 /var/log/auth.log
Jan 13 23:48:41 kali sudo[117105]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=0)
```

Redémarrer la machine pour vérifier que le script se lance automatiquement :

Sudo reboot



vérifier son état après le démarrage :

sudo systemctl status surveillance_sudo.service

```
root@kali: /home/kali
Session Actions Edit View Help
(kali@kali)~]
$ sudo su
[sudo] password for kali:
(root@kali)~]
$ sudo systemctl status surveillance_sudo.service
● surveillance_sudo.service - Service de surveillance des tentatives sudo échouées
   Loaded: loaded (/etc/systemd/system/surveillance_sudo.service; enabled; preset: disabled)
   Active: active (running) since Tue 2026-01-13 23:39:27 EST; 1min 31s ago
 Invocation: fd06e4186f9943e694b4bf8da33f0609
    Main PID: 684 (surveillance_su)
      Tasks: 4 (limit: 4339)
    Memory: 5.7M (peak: 6.3M)
       CPU: 155ms
   CGroup: /system.slice/surveillance_sudo.service
            └─684 /bin/bash /home/kali/Desktop/surveillance_sudo.sh
              └─695 sudo tail -Fn0 /var/log/auth.log
                └─696 /bin/bash /home/kali/Desktop/surveillance_sudo.sh
                  └─712 tail -Fn0 /var/log/auth.log

Jan 13 23:39:27 kali systemd[1]: Started surveillance_sudo.service - Service de surveillance des tentatives sudo échouées.
Jan 13 23:39:27 kali surveillance_sudo.sh[684]: == Surveillance des tentatives d'accès root échouées ==
Jan 13 23:39:27 kali surveillance_sudo.sh[684]: Script démarré à 2026-01-13 23:39:27
Jan 13 23:39:27 kali sudo[695]:      root : PWD=/ ; USER=root ; COMMAND=/usr/bin/tail -Fn0 /var/log/auth.log
Jan 13 23:39:27 kali sudo[695]: pam_unix(sudo:session): session opened for user root(uid=0) by (uid=0)

(root@kali)~]
$
```

Le script marche à la perfection.

Les tentatives d'accès root échouées n'étaient pas surveillées sur le système. Cela signifiait qu'un utilisateur malveillant pouvait tenter à répétition d'élever ses privilèges via sudo, sans générer d'alerte ni laisser de trace exploitable dans les journaux. Cette absence de supervision réduisait la capacité de l'administrateur à détecter les tentatives d'intrusion locales et à réagir rapidement.

Pour remédier à cette faille, la première étape a consisté à activer la journalisation des actions sudo grâce au service rsyslog. Ce dernier a été configuré pour s'exécuter automatiquement au démarrage du système à l'aide des commandes :

```
sudo systemctl enable rsyslog
```

```
sudo systemctl start rsyslog
```

Une fois actif, rsyslog a permis de centraliser les journaux d'exécution et d'échec d'authentification dans le fichier `/var/log/auth.log`, garantissant ainsi la traçabilité des actions administratives.

Un script de surveillance dédié, nommé `surveillance_sudo.sh`, a ensuite été développé. Ce script analyse en continu les lignes de `/var/log/auth.log` et détecte les mentions relatives à des erreurs telles que « **incorrect password attempts** » ou « **authentication failure** ». Lorsqu'une tentative échouée est identifiée, le script exécute deux actions :

il enregistre l'événement dans un journal spécifique
`/var/log/alerte_sudo.log` ;

et il envoie simultanément une alerte mail locale à l'administrateur via le paquet mailutils, l'informant qu'une tentative sudo a été détectée sur la machine.

Pour assurer une surveillance permanente, le script a été intégré dans un service systemd nommé **surveillance_sudo.service**. Ce service se lance automatiquement au démarrage du système et redémarre de lui-même en cas d'arrêt forcé. Il garantit ainsi un fonctionnement continu et autonome de la détection. Après chaque redémarrage, le service reprend sans intervention manuelle, assurant la persistance de la supervision.

Grâce à ces actions combinées, le système est désormais capable de détecter, enregistrer et signaler automatiquement toute tentative d'accès root échouée. Chaque incident est consigné dans les logs et notifié à l'administrateur. La journalisation centralisée, couplée à la surveillance automatisée, renforce significativement la sécurité du système en donnant une visibilité complète sur les comportements suspects et une réaction rapide face aux tentatives d'intrusion.

13 - CONCLUSION

Ce projet, centré sur la **création d'une machine virtuelle vulnérable** et l'**audit de sécurité des systèmes Linux et Windows**, a permis d'acquérir une expérience complète et concrète du **cycle de gestion des vulnérabilités**. L'approche mise en œuvre a couvert toutes les phases essentielles de la cybersécurité : l'identification, l'exploitation contrôlée, l'analyse et la remédiation des vulnérabilités. Il s'agissait non seulement d'un travail technique, mais aussi d'un exercice méthodologique visant à reproduire des scénarios réalistes de détection et de durcissement (hardening) de systèmes d'exploitation.

La conception délibérée de failles-permissions incorrectes sur `/etc/shadow`, tâche cron mal sécurisée, comptes Windows à mot de passe faible et partage réseau trop permissif a permis de mieux comprendre comment des erreurs de configuration peuvent être exploitées. Les **scripts d'audit** développés (pour Linux et Windows) se sont montrés efficaces pour détecter ces vulnérabilités et évaluer leur impact réel. Les **scripts de surveillance** ont permis d'aller plus loin en intégrant une **dimension de détection en temps réel**, avec l'ajout de **systèmes d'alerte par mail** et de journaux spécifiques pour tracer les événements et les actions critiques.

L'un des apports majeurs de cette étude réside dans la **mise en œuvre de l'automatisation via systemd** : les scripts de supervision, tels que celui dédié à la surveillance des tentatives sudo échouées, ont été configurés pour s'exécuter automatiquement au démarrage du système. Cette automatisation rend la machine capable de se surveiller elle-même sans intervention humaine, assurant une vigilance continue et une traçabilité permanente.

Sur le plan personnel, ce projet a permis de **renforcer la maîtrise des outils d'administration système et de scripting Bash**, tout en apprenant à exploiter, interpréter et sécuriser les **fichiers de logs** système. Il a également mis en évidence la nécessité d'une documentation rigoureuse, de la compréhension du fonctionnement de services tels que rsyslog, cron, systemd et mailutils, ainsi que de la patience et de la persévérance pour résoudre des problèmes concrets.

Enfin, au-delà de la réussite technique, ce projet illustre l'importance d'une **cybersécurité proactive** : anticiper, surveiller et réagir rapidement. Les vulnérabilités corrigées, la mise en place de la journalisation automatisée et l'intégration de la surveillance au démarrage ont transformé un système initialement vulnérable en un environnement **renforcé, stable et auto-supervisé**. Le projet atteint ainsi pleinement son objectif : démontrer qu'à travers des outils simples mais bien configurés, il est possible d'assurer un **haut niveau de détection, de prévention et de réactivité** dans la gestion de la sécurité des systèmes Windows et Linux.